

# The Practitioner's Blueprint for Secure AI

By John M. Willis, Quantum Powered Security, Inc.



August 2025

## Copyright and License

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc.

This manuscript is licensed under the Creative Commons Attribution 4.0 International License (CC BY 4.0). You are free to share and adapt this work for any purpose, including commercial use, provided appropriate attribution is given.

License: <https://creativecommons.org/licenses/by/4.0/>

## Patent Notice

The concepts, architectures, and reference designs presented in this work are intended to encourage adoption, adaptation, and further innovation. Readers are encouraged to tailor PBSAI to their own environments, products, and services. Novel implementations, extensions, and improvements developed by others may be eligible for intellectual property protection under applicable patent laws.

The authors likewise reserve all rights to pursue patent protection for their own inventions, implementations, improvements, and future developments related to PBSAI. Certain aspects of this work are the subject of pending patent applications. Except as expressly stated by applicable law, no patent rights are granted or implied by this publication or its CC BY 4.0 license.

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

# **Volume 2: The Multi-Agent AI Defensive Cybersecurity Ecosystem**

**Domain D – Threat Intel, SA**

## Table of Contents

|                                                                             |    |
|-----------------------------------------------------------------------------|----|
| Domain D - Threat Intelligence, Situational Awareness, and Monitoring ..... | 4  |
| D1. Threat Intel Aggregator Agent .....                                     | 4  |
| Agent Blueprint [Informative] .....                                         | 4  |
| Technical Implementation Details (D1) [Informative] .....                   | 15 |
| MCP-Native Protocol Specification (D1) [Normative] .....                    | 18 |
| D2. SIEM Analyst Agent.....                                                 | 19 |
| Agent Blueprint [Informative] .....                                         | 19 |
| Technical Implementation Details (D2) [Informative] .....                   | 32 |
| MCP-Native Protocol Specification (D2) [Normative] .....                    | 34 |
| D3. UEBA Analysis Agent .....                                               | 35 |
| Agent Blueprint [Informative] .....                                         | 35 |
| Technical Implementation Details (D3) [Informative] .....                   | 47 |
| MCP-Native Protocol Specification (D3) [Normative] .....                    | 50 |
| D4. Autonomous Hunter Agent .....                                           | 50 |
| Agent Blueprint [Informative] .....                                         | 50 |
| Technical Implementation Details (D4) [Informative] .....                   | 59 |
| MCP-Native Protocol Specification (D4) [Normative] .....                    | 62 |
| D5. Exposure Mapping Agent (ASM) .....                                      | 62 |
| Agent Blueprint [Informative] .....                                         | 62 |
| Technical Implementation Details (D5) [Informative] .....                   | 74 |
| MCP-Native Protocol Specification (D5) [Normative] .....                    | 76 |
| D6. Honeypot Controller Agent .....                                         | 77 |
| Agent Blueprint [Informative] .....                                         | 77 |
| Technical Implementation Details (D6) [Informative] .....                   | 86 |
| MCP-Native Protocol Specification (D6) [Normative] .....                    | 88 |

# Domain D - Threat Intelligence, Situational Awareness, and Monitoring

## D1. Threat Intel Aggregator Agent

### Agent Blueprint [Informative]

**Purpose:** Normalize and score cyber threat intel (CTI) from multiple sources; correlate with internal sightings; publish enriched STIX bundles and IntelIOC objects; recommend courses of action (COAs) such as block/sinkhole with explicit TTLs.

### Operational Narrative [Informative]

#### Inputs used (authoritative sources):

- **TAXII 2.x / STIX 2.1** — curated intel collections (indicators, malware, TTPs); fields used: type, id, pattern, valid\_from, relationships, confidence, marking\_definitions.
- **OSINT Feeds (HTTP/S, RSS/Atom/JSON)** — vendor blogs, CT logs, social, paste sites; fields used: published, artifacts (domains, hashes, yara), summary, risk\_tags, source reputation.
- **Internal Sightings (SIEM/EDR via OTel/Syslog/REST)** — IOC hits, detections, triage tags; fields used: asset, process context, severity, timestamps, case refs.

#### Model training / knowledge (what the LLM relies on):

- Style and rubric prompt-pack for CTI normalization (STIX 2.1 mapping, ATT&CK/D3FEND terms, IOC hygiene rules).
- RAG sources: intel KB (family aliases, infrastructure overlap), source-reputation ledger, FP history, internal asset criticality map. Do **not** train on regulated telemetry; fetch via evidence\_refs.
- Guardrails: allow-list outbound to TAXII endpoints, read-only SIEM queries, scoped keys for publishing; deny auto-block outside approved COA endpoints.

#### Decisions it makes (deterministic + model-assisted):

- **Normalization** to STIX 2.1 (indicator, observed-data, relationship) with deduplication and marking propagation (TLP).
- **Scoring** of IOCs (0–100) combining source reputation, recency, corroboration, internal sightings, enrichment (DGA/fast-flux/YARA), and FP history.

- **COA selection** with TTL: block-ip, sinkhole-domain, quarantine-hash, or watchlist; include rationale and expiration.
- **Classification** (C1→C3) based on inclusion of sensitive internal context.

#### Routing / where outputs go:

- **Enriched STIX bundles** → TAXII collection or object storage (versioned).
- **IntelIOC events** → streaming bus (Kafka/AMQP) and REST for consumers (SIEM, EDR, TIP).
- **COA recommendations** → firewall/EDR/DNS REST endpoints with `course_of_action` and `ttl_hours`; tickets on HITL-required cases.

#### Automation scope vs. manual/HITL:

- Fully automated: feed ingestion, normalization, dedup, scoring, STIX publish, IntelIOC streaming.
- **HITL required:** COA that would affect CrownJewels assets; confidence < `theta_autoblock`; classification=C3; or region constraints (e.g., constraints contains "no\_auto\_block:true").
- Manual outside agent: vendor contract/SLAs, legal takedowns, inter-org intel sharing MOUs.

### Security Domain: Threat Intelligence, Situational Awareness, and Monitoring

#### Inputs (native protocols consumed) [Informative]

1. **TAXII 2.x / STIX 2.1** — pull curated intel (indicators, malware, relationships).
2. **OSINT Feeds (HTTP/S, RSS/Atom/JSON)** — vendor blog posts, CT logs, social/paste platforms.
3. **Internal Sightings (OTel/Syslog/REST)** — SIEM/EDR IOC sightings and triage context.

#### Example: Consumed Protocol — TAXII / STIX 2.1 [Informative]

Native payload

```
{
  "type": "indicator",
  "spec_version": "2.1",
```

```
"id": "indicator--c05c1a9e-0c0a-4c4c-8e32-2c6a1b2d9f01",
"created": "2025-08-15T09:00:00Z",
"modified": "2025-08-15T09:00:00Z",
"name": "C2 IP for campaign X",
"indicator_types": ["malicious-activity"],
"pattern": "[ipv4-addr:value = '203.0.113.99']",
"pattern_type": "stix",
"valid_from": "2025-08-15T09:00:00Z",
"confidence": 70
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-d1-taxii-1111-2222-3333-4444",
    "thread_id": "uuid-stix-collection-campaign-x",
    "task_id": "uuid-aaaa-bbbb-cccc-dddd",
    "role": "ThreatIntelAggregatorAgent",
    "intent": "assess",
    "policy_refs": ["SI-4", "RA-3"],
    "course_of_action": "block-ip",
    "ttl_hours": 72,
    "decision_basis": {
      "evidence_refs": ["uri://taxii/collections/campaign-x/indicator--c05c1a9e"],
      "confidence": 0.9,
      "explanation_ref": "uri://kb/cti/scoring#ip-rep-weighting"
    },
  },
}
```

```

"provenance": {
  "producer_spiffe": "spiffe://enterprise/threat/d1-intel-aggregator",
  "signing_kid": "kid-taxii-d1-01",
  "attestation_ref": "uri://slsa/attestations/d1-intel@sha256:taxii01"
},
"classification": "C1",
"legal_hold": false
},
"native_payload": { ... }
}

```

**Example: Consumed Protocol — OSINT Feeds (HTTP/S RSS/JSON) [Informative]**  
Native payload

```

{
  "source": "VendorBlog",
  "url": "https://example.vendor.com/blog/campaign-x-c2-rotation",
  "published": "2025-08-15T08:30:00Z",
  "artifacts": {
    "domains": ["api-secure-login[.]com"],
    "hashes_sha256": ["8f1b...c2a9"],
    "yara_rules": ["rule campaignX_C2_dns { strings: $d = \"api-secure-login\" condition: $d }"]
  },
  "summary": "Campaign X rotating C2 infra; DNS-fast-flux noted.",
  "risk_tags": ["fast-flux", "credential-harvest"]
}

```

MCP-wrapped payload

```

{

```

```
"mcp_context": {
  "mcp_version": "0.9",
  "mission_id": "uuid-d1-osint-5555-6666-7777-8888",
  "thread_id": "uuid-osint-campaign-x",
  "task_id": "uuid-9911-8822-7733-6644",
  "role": "ThreatIntelAggregatorAgent",
  "intent": "assess",
  "policy_refs": ["SI-4", "PM-16"],
  "course_of_action": "sinkhole-domain",
  "ttl_hours": 48,
  "decision_basis": {
    "evidence_refs": ["https://example.vendor.com/blog/campaign-x-c2-rotation"],
    "confidence": 0.8,
    "explanation_ref": "uri://kb/cti/osint-trust-model#vendor-blogs"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/threat/d1-intel-aggregator",
    "signing_kid": "kid-osint-d1-02",
    "attestation_ref": "uri://slsa/attestations/d1-intel@sha256:osint02"
  },
  "classification": "C1",
  "legal_hold": false
},
"native_payload": { ... }
}
```

## Example: Consumed Protocol — Internal Sightings (SIEM/EDR via OTel/Syslog/REST) [Informative]

Native payload

```
{
  "timestamp": "2025-08-15T10:11:07Z",
  "event_type": "ioc_sighting",
  "ioc": {"type": "ipv4", "value": "203.0.113.99", "source": "TAXII-campaign-x"},
  "asset": {"host": "srv-001", "ip": "10.2.14.5"},
  "context": {"process": "/usr/bin/curl", "dest_port": 443, "tls_sni": "api-secure-login.com"},
  "severity": "high",
  "triage": {"status": "new", "case_ref": null}
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-d1-sighting-aaaa-bbbb-cccc-dddd",
    "thread_id": "uuid-ioc-203.0.113.99",
    "task_id": "uuid-1122-3344-5566-7788",
    "role": "ThreatIntelAggregatorAgent",
    "intent": "assess",
    "policy_refs": ["SI-4", "IR-4"],
    "course_of_action": "block-ip",
    "ttl_hours": 168,
    "decision_basis": {
      "evidence_refs": ["uri://siem/ioc_sighting/srv-001/2025-08-15T10:11:07Z"],
      "confidence": 0.98,
    }
  }
}
```

```

    "explanation_ref": "uri://models/cti/scoring#external+internal-sighting-boost"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/threat/d1-intel-aggregator",
    "signing_kid": "kid-siem-d1-03",
    "attestation_ref": "uri://slsa/attestations/d1-intel@sha256:siem03"
  },
  "classification": "C2",
  "legal_hold": true
},
"native_payload": { ... }
}

```

### Outputs (native) [Informative]

- STIX 2.1 **bundles** (published to TAXII or object storage).
- **IntelIOC** events (Kafka/AMQP/REST) for downstream consumers.
- **COA recommendations** to firewall/EDR/DNS (REST) with `course_of_action` and `ttl_hours`.

### MCP context (required) [Informative]

`mission_id`; `role="ThreatIntelAggregatorAgent"`; `intent="assess"`; `policy_refs` (e.g., SI-4, RA-3); `course_of_action`; `ttl_hours`; `provenance` (SPIFFE ID, signing key, attestation)

### MCP context (optional) [Informative]

`classification` (C1–C3); `decision_basis` (`evidence_refs`, `confidence`, `explanation_ref`); `constraints` (e.g., `"region:eu"`, `"no_auto_block:true"`); `legal_hold`

### Enforcement note [Informative]

PEPs (firewall/EDR/DNS) MUST verify: `signature`, `provenance.attestation`, `course_of_action`, `ttl_hours` within policy, and `classification` ≤ allowed; HITL token required for CrownJewels or when constraints include `no_auto_block:true`.

### NIST SP 800-160v2 linkage [Informative]

Anticipate/Withstand: leverage external intel to pre-position defenses; Recover: rapid COA distribution with bounded TTLs.

### **Automation feasibility [Informative]**

High (ingest/normalize/score/publish automated; COA execution auto or HITL per policy).

---

## **Output Contracts (merged) [Informative]**

### **OC-1: STIXBundlePublish [Informative]**

- **Producer(s):** D1
- **Topic/Path:** taxii://collections/<org>/<stream> or s3://intel-bundles/<date>/<bundle\_id>.stix2
- **Schema/Format:** STIX 2.1 bundle; manifest + objects; includes marking\_definitions and relationships
- **Classification:** C1 default; C2 when internal sightings embedded; C3 when asset context present
- **Delivery:** at-least-once
- **Ordering:** per-bundle-id
- **Idempotency-Key:** sha256(bundle\_id, version)
- **Ack/Nack:** TAXII 202/200 or object store 201 = ACK; 4xx/5xx = NACK
- **Timeouts/Retry:** ack<=60s; exp-backoff<=5x; dead-letter to intel.publish.dlq
- **Side-Effects:** update bundle index; write evidence\_refs; emit summary metric
- **HITL Token:** none
- **Observability:** trace\_id, mission\_id, evidence\_refs, decision\_basis.\*, classification\_label, provenance.attestation
- **Retention/TTL:** 7 years (C1/C2); per legal\_hold if true

### **Schema Capsule (OC-1) [Normative]**

**Requirement Level:** Required

**Condition:** Always

schema\_id=STIXBundlePublish@1.0 | json\_schema\_uri=uri://schema/stix-bundle-publish-1.0.json | sha256= | producers=D1 | consumers=TAXII-01, TIP-01 |

accepts=1.0–1.x

**Conformance:** Normative.

---

## OC-2: IntelIOCEvent [Informative]

- **Producer(s):** D1
- **Topic/Path:** intel.ioc.v1 (Kafka/AMQP) and /intel/ioc (REST)
- **Schema/Format:** IntelIOC@1.0 (type, value, score, tlp, first\_seen, last\_seen, tags, ttl\_hours)
- **Classification:** C1–C2
- **Delivery:** at-least-once (stream) and idempotent REST
- **Ordering:** per (ioc\_type, ioc\_value)
- **Idempotency-Key:** sha256(ioc\_type, ioc\_value, first\_seen\_floor\_1h)
- **Ack/Nack:** stream offset commit / HTTP 201; NACK on schema or stale TTL
- **Timeouts/Retry:** stream retry per broker; REST exp-backoff<=5x
- **Side-Effects:** update IOC registry; notify subscribers
- **HITL Token:** none
- **Observability:** trace\_id, mission\_id, score, decision\_basis.confidence, ttl\_hours
- **Retention/TTL:** until ttl\_hours expiry or revocation

## Schema Capsule (OC-2) [Normative]

**Requirement Level:** Conditionally Required

**Condition:** When internal consumers integrate via streaming bus or REST IOC API  
schema\_id=IntelIOC@1.0 | json\_schema\_uri=uri://schema/intel-ioc-1.0.json |  
producers=D1 | consumers=SIEM-01, EDR-01, TIP-01

**Conformance:** Normative when condition is met.

---

## OC-3: COARecommendation [Informative]

- **Producer(s):** D1
- **Topic/Path:** /coa/recommendations (REST) and intel.coa.v1 (bus)
- **Schema/Format:** COARecommendation@1.0 (target\_id, target\_type, course\_of\_action, ttl\_hours, not\_before, not\_after, rationale)

- **Classification:** C2+
- **Delivery:** exactly-once per (target\_id, course\_of\_action) within ttl window
- **Ordering:** per target\_id
- **Idempotency-Key:** sha256(target\_id, course\_of\_action, ttl\_floor\_1h)
- **Ack/Nack:** 202 Accepted with enforcement\_ref; NACK on policy violation or missing HITL token
- **Timeouts/Retry:** ack<=30s; exp-backoff<=5x; escalate to HITL on repeated NACK
- **Side-Effects:** open/change ticket; append enforcement journal entry
- **HITL Token:** required for CrownJewels or classification=C3
- **Observability:** trace\_id, mission\_id, policy\_refs, ttl\_hours, decision\_basis.\*, classification\_label, provenance.attestation
- **Retention/TTL:** 1 year (journal); COA expiry per ttl\_hours

### **Schema Capsule (OC-3) [Normative]**

**Requirement Level:** Conditionally Required

**Condition:** When automated enforcement or recommendation workflows are enabled  
 schema\_id=COARecommendation@1.0 | json\_schema\_uri=uri://schema/coa-recommendation-1.0.json | producers=D1 | consumers=FW-PEP-01, DNS-PEP-01, EDR-PEP-01

**Conformance:** Normative when condition is met.

### **State machine (concise) [Informative]**

states = { idle, fetching, normalizing, scoring, correlating, publishing, recommending, contestation\_workflow, failed, closed }

transition(idle -> fetching) when feed\_schedule\_tick or manual\_refresh

transition(fetching -> normalizing) when inputs retrieved

transition(normalizing -> scoring) when STIX mapping succeeds

transition(scoring -> correlating) when score computed

transition(correlating -> publishing) when correlations resolved and bundle built

transition(publishing -> recommending) when score >= theta\_recommend or

internal\_sighting\_present = true

transition(\* -> contestation\_workflow) when false\_positive\_claim = true or

stakeholder\_disagreement\_score >= 0.5

transition(\* -> failed) on schema\_error or timeout

timeout(publishing, 60s) -> failed; retry <= 5 with exp backoff  
 idempotency\_key = sha256(bundle\_id, version) for publish; sha256(ioc\_type, ioc\_value, first\_seen\_floor\_1h) for IntelIOC; sha256(target\_id, course\_of\_action, ttl\_floor\_1h) for COA

---

### Output Contracts Summary [Normative]

| Output Contract           | Requirement Level             | Trigger Condition                                         | Business Impact                   |
|---------------------------|-------------------------------|-----------------------------------------------------------|-----------------------------------|
| OC-1<br>STIXBundlePublish | <b>Required</b>               | Always                                                    | Core intel distribution           |
| OC-2 IntelIOCEvent        | <b>Conditionally Required</b> | Internal consumers via bus/API                            | Real-time IOC dissemination       |
| OC-3<br>COARecommendation | <b>Conditionally Required</b> | Automated enforcement or recommendation workflows enabled | Pre-positioned defensive controls |
| OC-4 (unused)             | <b>Optional</b>               | (reserve for deployment-specific extensions)              | —                                 |
| OC-5 (unused)             | <b>Optional</b>               | (reserve)                                                 | —                                 |
| OC-6 (unused)             | <b>Optional</b>               | (reserve)                                                 | —                                 |

#### Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

---

### Policies and HITL gates [Informative]

- policy\_refs: SI-4 (monitoring), RA-3 (risk assessment), IR-4 (incident handling)
- **HITL required:** any COA on CrownJewels; classification=C3; model\_confidence < theta\_autoblock; constraints include no\_auto\_block:true; region exceptions.

- **Automatic HITL escalation triggers:** model\_drift\_detected = true; stakeholder\_disagreement\_score >= 0.5; FP\_rate\_24h > threshold.
- **Manual outside agent:** legal takedowns; third-party notification.

### SLOs and KPIs [Informative]

- BundlePublishAck\_p95 <= 60 s
- IntellOCPropagation\_p95 <= 30 s
- COAApplAck\_p95 <= 30 s
- FalsePositiveRate\_7d <= 2 percent
- MeanTTLExpiryAccuracy\_7d >= 95 percent
- DriftDetect\_MTTD <= 24 h

### Outputs index [Informative]

[OC-1 STIXBundlePublish], [OC-2 IntellOCEvent], [OC-3 COARecommendation]

## Technical Implementation Details (D1) [Informative]

### Model and training profile [Informative]

model\_id=cti-aggregator-text; temperature=0.0; max\_tokens\_out=600  
 prompt\_pack\_id=cti-normalize-v1 (STIX mapping rules, IOC hygiene, ATT&CK/D3FEND lexicon)  
 RAG: sources={intel-kb, source-reputation-ledger, fp-history, asset-criticality};  
 max\_docs=10; min\_similarity=0.78; citations required  
 fine\_tuning/adapters: none initially; eval gates on mapping accuracy and hallucination bounds  
 guardrails: constrained tools (TAXII pull, SIEM read, publish to TAXII/bus/COA endpoints); deny arbitrary network posts

### Memory and state [Informative]

working\_memory.max\_tokens=4k; eviction=recency\_then\_importance  
 episodic\_memory: per mission\_id journal of bundles, IOC decisions, COAs; ttl=365d  
 semantic\_memory: namespaces=["cti", "source-rep", "fp-history", "assets"];  
 embeddings=text-embedding-sec-v1; k=10  
 durable\_state\_store: event-sourced journal; snapshot per bundle publish  
 consistency: at-least-once (publish/IOC); exactly-once (COA per target\_id)  
 idempotency: per Output Contracts

## Decision and routing logic [Informative]

Define normalized features:

- src\_rep in [0,1] (source reputation), recency in [0,1], sighting in {0,1}, enrich in [0,1] (DGA/fast-flux/YARA/sandbox), fp\_hist in [0,1] (higher means more FPs historically).

### IOC score (0–100):

score =  $100 * (0.35 * \text{src\_rep} + 0.25 * \text{recency} + 0.25 * \text{sighting} + 0.15 * \text{enrich}) * (1 - 0.4 * \text{fp\_hist})$

### Confidence (0–1):

confidence =  $\min(1.0, \text{score}/100 + 0.1 * \text{sighting})$

### TTL policy (hours):

base\_ttl(ip)=24, base\_ttl(domain)=48, base\_ttl(url)=24, base\_ttl(hash)=168

ttl\_hours =  $\text{clamp}(\text{base\_ttl}(\text{type}) * (0.5 + 0.5 * \text{confidence}) * (1 + 0.25 * \text{sighting} - 0.25 * \text{fp\_hist}), 6, 168)$

### COA selection:

if type in {ip, url} and (sighting=1 and confidence>=0.85): coa="block-ip"

else if type=domain and fast\_flux=1 and confidence>=0.75: coa="sinkhole-domain"

else if type=hash and confidence>=0.80: coa="quarantine-hash"

else: coa="watchlist"

### HITL override:

HITL required if (asset in CrownJewels) or (classification=C3) or (confidence < theta\_autoblock)

Routing: bundles→TAXII; IntellIOC→bus/API; COA→PEPs; apply backpressure when queue\_depth > threshold.

## Model Risk Management [Informative]

continuous\_validation: daily (golden STIX mapping set; adversarial IOC strings)

thresholds: mapping\_accuracy >= 99.5 percent; score\_stability drift < 1.5 percentage points/48h → else auto\_HITL

red\_team\_cycle: monthly (evasion, DGA variants, homoglyphs)

rollback\_policy: revert model\_id on sustained eval\_drop >= 1.5 percentage points over 48 h

## Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision\_rationale\_template: sources, transformations, relationships, score factors, TTL derivation

UI/API: expose classification\_label, provenance.attestation, decision\_rationale\_url

audit\_log\_format: JSONL with stable fields; retention aligned to classification or legal\_hold

### **Incident Response Integration [Informative]**

Emit COARecommendation to enforcement systems; on NACK or conflict open SOAR case, attach bundle refs and IOC rationale.

### **Change Impact Assessment [Informative]**

Track downstream block volume and FP signals; adjust thresholds with governance review; emit score/TTL change deltas to IntellIOC stream.

### **Stakeholder Feedback Loop [Informative]**

Accept FP/TP votes from SOC/TI analysts; emit FeedbackIngestion events into learning queue (governance reviewed); never auto-train on regulated telemetry.

### **Data Sovereignty and Legal Hold [Informative]**

Honor constraints (e.g., region:eu); legal\_hold=true → override purge/TTL, restrict dissemination.

### **Interfaces (links only) [Informative]**

Consumes: TAXII/STIX, OSINT HTTP/S, SIEM/EDR OTel/Syslog/REST

Produces: OC-1 STIXBundlePublish; OC-2 IntelIOCEvent; OC-3 COARecommendation

### **Safety and abuse prevention [Informative]**

kill\_switch on signature or schema validation failures; sandbox COA when provenance missing; blast-radius caps ( $\leq 100$  new blocks/hour unless HITL); QPS/cost limits.

### **Testing and validation [Informative]**

Contract tests per Schema Capsules; offline replay of historical feeds; red-team IOC mutation tests; drift checks with rollback.

### **Deployment and lifecycle [Informative]**

HPA on feed/queue depth; canary COA endpoints; SBOM + in-toto/SLSA attestations; sign bundles and COAs.

---

## **References / Standards [Informative]**

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

NIST SP 800-160 Vol. 2; NIST SP 800-61 Rev. 2; NIST SP 800-150 (Guide to Cyber Threat Information Sharing); NIST SP 800-137; MITRE ATT&CK/D3FEND; **STIX 2.1** and **TAXII 2.x** (OASIS); OTel; CIS v8.

---

## MCP-Native Protocol Specification (D1) [Normative]

*(Canonical schemas and validation live here; keep example payloads synchronized with the Agent Blueprint.)*

- **Native Protocol(s) Consumed:** TAXII 2.x / STIX 2.1; OSINT HTTP/S (RSS/Atom/JSON); Internal Sightings via OTel/Syslog/REST
- **Native Protocol(s) Produced:** STIX 2.1 bundles; IntelIOC events (bus/REST); COA recommendations (REST/bus)
- **MCP Context Fields:**
  - **Required:** mission\_id; role="ThreatIntelAggregatorAgent"; intent="assess"; policy\_refs; course\_of\_action; ttl\_hours; provenance (SPIFFE, signing key, attestation)
  - **Optional:** classification; decision\_basis (evidence\_refs, confidence, explanation\_ref); constraints; legal\_hold
- **Enforcement Note:** PEPs MUST verify signature, provenance, classification bounds, course\_of\_action, and ttl\_hours before enforcement; HITL tokens required per Policies and HITL gates.
- **Versioning and compatibility; producers/consumers registry:** authoritative here; see Schema Capsules for accepted ranges and EOL dates.
- **Example payloads:** native and MCP-wrapped (authoritative, mirrored from Agent Blueprint).
- **Transparency hooks:** classification\_label, provenance.attestation, decision\_rationale\_url available to downstream UIs/APIs.

**Conformance:** This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

## D2. SIEM Analyst Agent

### Agent Blueprint [Informative]

**Purpose:** Correlate multi-source telemetry (OTel logs/metrics/traces + EDR/IAM/Cloud logs) to generate high-fidelity **DetectionEvent** objects (ATT&CK-tagged) and link or open cases.

### Operational Narrative [Informative]

#### Inputs used (authoritative sources):

- **OpenTelemetry (OTel) Logs/Metrics/Traces** — normalized events from collectors/pipelines; key fields: resource.\* (service/host/env), attributes.\* (process/file/net/auth), span links, trace\_id.
- **EDR Telemetry (REST/Syslog/OTLP)** — process trees, alerts, sensor signals; key fields: process lineage, hashes, policy, action\_taken.
- **IdP/IAM Auth Logs (REST/JSON/Syslog)** — sign-in outcomes, MFA signals, device/app context; key fields: decision, risk\_signals, geo/asn/ip, user/app.
- **Cloud Provider Logs (AWS CloudTrail / Azure Activity / GCP Audit)** — API/data events; key fields: eventName, resource, identity (MFA, role), parameters (bucket/key), source IP.

#### Model training / knowledge (what the LLM relies on):

- **Prompt pack / rubric** for correlation semantics, ATT&CK mapping, Sigma-style patterns, and severity/confidence calibration.
- **RAG sources:** rule catalog (Sigma/Detections KB), ATT&CK tactic/technique encyclopedia, asset criticality registry, suppression/FP history. Do not train on regulated telemetry; access via evidence\_refs.
- **Guardrails:** read-only scopes to SIEM/EDR/Cloud logs; case APIs scoped to create/update links; enforce constraints=["timebox\_2m"] in all correlation paths.

#### Decisions it makes (deterministic + model-assisted):

- **Correlation** across OTel/EDR/IAM/Cloud within sliding window W (default 5 min) producing a single DetectionEvent with correlation\_keys (e.g., user, host, trace\_id, cloud\_role).
- **ATT&CK tagging** (technique, sub-technique, tactic) with mapping\_refs (rule pages, ATT&CK IDs).

- **Severity & confidence** computation using rule strength, signal agreement, asset criticality, and FP-history.
- **Case handling:** upsert case link (attach to existing or open new) and annotate with evidence\_refs; escalate per thresholds.

#### Routing / where outputs go:

- **DetectionEvent** → Kafka/AMQP topic secops.detections.v1 and optional REST /detections.
- **Case links** → TheHive / Jira / ServiceNow / SOAR via their REST APIs (case\_ref echoed in DetectionEvent).
- **Tickets/alerts** → on pipeline SLA breach, schema failure, or conflicting mappings.

#### Automation scope vs. manual/HITL:

- Fully automated: ingestion, normalization, correlation, ATT&CK mapping, DetectionEvent emission, case link upsert for sev <= medium or non-CrownJewels.
- **HITL required:** sev >= high on CrownJewels, classification=C3, model\_confidence < theta\_auto, conflicting technique mappings.
- Manual outside agent: long-form investigation writeups, contact with business owners, major incident declaration.

---

### Security Domain: Threat Intelligence, Situational Awareness, and Monitoring

#### Inputs (native protocols consumed) [Informative]

1. **OpenTelemetry (OTel) Logs/Metrics/Traces** — normalized telemetry from collectors/pipelines.

##### **Example (OTel log: obfuscated PowerShell execution)**

Native payload

```
{
  "timestamp": "2025-08-15T12:01:05Z",
  "resource": {
    "service.name": "win-sysmon-ingestor",
    "host.name": "WIN-SRV-02",
```

```

    "environment": "production"
  },
  "attributes": {
    "event_type": "process_create",
    "process.name": "powershell.exe",
    "process.command_line": "powershell -nop -w hidden -enc SQBt+c3VzcGVjdA==",
    "parent.process.name": "w3wp.exe",
    "user": "IIS APPPOOL\\ProdAppPool"
  }
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-d2-otel-1111-2222-3333-4444",
    "thread_id": "uuid-WIN-SRV-02-proc-2025-08-15T12:01:05Z",
    "task_id": "uuid-a1b2-c3d4-e5f6-7788",
    "role": "SIEMAnalystAgent",
    "intent": "detect",
    "constraints": ["timebox_2m"],
    "policy_refs": ["SI-4", "AU-6", "IR-4"],
    "decision_basis": {
      "evidence_refs": ["uri://otel/logs/win-sysmon/WIN-SRV-02/2025-08-15T12:01:05Z"],
      "mapping_refs": ["ATT&CK:T1059.001"],
      "confidence": 0.92,
      "explanation_ref": "uri://sigma/rules/windows/powershell_obfuscated_exec"
    }
  },

```

```

"provenance": {
  "producer_spiffe": "spiffe://enterprise/threat/siem-analyst-agent",
  "signing_kid": "kid-otlp-d2-01",
  "attestation_ref": "uri://slsa/attestations/siem-analyst@sha256:otlp01"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { /* object exactly as above */ }
}

```

2. **EDR Telemetry (REST/Syslog/OTLP)** — process trees, alerts, sensor signals.  
Native payload

```

{
  "alert_id": "edr-ALRT-99301",
  "host": "WIN-SRV-02",
  "time": "2025-08-15T12:01:07Z",
  "title": "Suspicious PowerShell with encoded command",
  "severity": "high",
  "process_tree": [
    {"name": "w3wp.exe", "pid": 3412},
    {"name": "powershell.exe", "pid": 8790, "cmd": "powershell -enc SQBt+c3VzcGVjdA==" }
  ],
  "hash_sha256": "2f5a...c1e9",
  "policy": "Prod-Servers",
  "action_taken": "none"
}

```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-d2-edr-5555-6666-7777-8888",
    "thread_id": "uuid-edr-ALRT-99301",
    "task_id": "uuid-9911-8822-7733-6644",
    "role": "SIEMAnalystAgent",
    "intent": "detect",
    "constraints": ["timebox_2m"],
    "policy_refs": ["SI-4", "IR-4"],
    "decision_basis": {
      "evidence_refs": ["uri://edr/alerts/edr-ALRT-99301"],
      "mapping_refs": ["ATT&CK:T1059.001"],
      "confidence": 0.95,
      "explanation_ref": "uri://kb/detections/edr-powershell-encoded"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/threat/siem-analyst-agent",
      "signing_kid": "kid-edr-d2-02",
      "attestation_ref": "uri://slsa/attestations/siem-analyst@sha256:edr02"
    },
    "classification": "C2",
    "legal_hold": true
  },
  "native_payload": { /* object exactly as above */ }
}
```

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

### 3. IdP/IAM Auth Logs (REST/JSON/Syslog) — sign-in events and risk signals.

Native payload

```
{
  "event_id": "signin-9a12",
  "user": "E102993",
  "app": "gcp-console",
  "client": "Chrome 125",
  "ip": "198.51.100.44",
  "asn": "AS15169",
  "geo": "US-CA",
  "time": "2025-08-15T12:01:10Z",
  "decision": "challenge_mfa",
  "risk_signals": ["new_device", "unfamiliar_asn"]
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-d2-iam-aaaa-bbbb-cccc-dddd",
    "thread_id": "uuid-signin-signin-9a12",
    "task_id": "uuid-1122-3344-5566-7788",
    "role": "SIEMAnalystAgent",
    "intent": "detect",
    "constraints": ["timebox_2m"],
    "policy_refs": ["SI-4", "AC-7", "IA-2"],
    "decision_basis": {
      "evidence_refs": ["uri://idp/signin/signin-9a12"],

```

```

    "mapping_refs": ["ATT&CK:T1078"],
    "confidence": 0.85,
    "explanation_ref": "uri://kb/detections/auth/new-device-unfamiliar-asn"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/threat/siem-analyst-agent",
    "signing_kid": "kid-idp-d2-03",
    "attestation_ref": "uri://slsa/attestations/siem-analyst@sha256:idp03"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { /* object exactly as above */ }
}

```

4. **Cloud Provider Logs (CloudTrail/Azure/GCP Audit)** — cloud API and data-plane access.  
Native payload

```

{
  "eventTime": "2025-08-15T12:01:20Z",
  "eventSource": "s3.amazonaws.com",
  "eventName": "GetObject",
  "awsRegion": "us-east-1",
  "sourceIPAddress": "203.0.113.200",
  "userIdentity": {"type": "AssumedRole", "sessionContext": {"mfaAuthenticated": "false"}},
  "requestParameters": {"bucketName": "payments-exports", "key": "pci/aug/transactions.csv"},
  "responseElements": {"x-amz-request-id": "ABCDEF123456"}
}

```

```
}
```

MCP-wrapped payload

```
{
```

```
"mcp_context": {  
  "mcp_version": "0.9",  
  "mission_id": "uuid-d2-cloud-7777-8888-9999-0000",  
  "thread_id": "uuid-ct-s3-getobject-payments-exports",  
  "task_id": "uuid-abcd-ef01-2345-6789",  
  "role": "SIEMAnalystAgent",  
  "intent": "detect",  
  "constraints": ["timebox_2m"],  
  "policy_refs": ["SI-4", "AU-6", "SC-28"],  
  "decision_basis": {  
    "evidence_refs": ["uri://aws/cloudtrail/s3/payments-exports/2025-08-15T12:01:20Z"],  
    "mapping_refs": ["ATT&CK:T1530"],  
    "confidence": 0.9,  
    "explanation_ref": "uri://kb/detections/cloud/s3-exfil-no-mfa"  
  },  
  "provenance": {  
    "producer_spiffe": "spiffe://enterprise/threat/siem-analyst-agent",  
    "signing_kid": "kid-ct-d2-04",  
    "attestation_ref": "uri://slsa/attestations/siem-analyst@sha256:ct04"  
  },  
  "classification": "C2",  
  "legal_hold": true  
},  
"native_payload": { /* object exactly as above */ }
```

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

}

### **Outputs (native) [Informative]**

- **DetectionEvent** via Kafka/AMQP/REST (includes ATT&CK technique, severity, confidence, correlation keys, case\_ref if present).
- **Case links** (TheHive/Jira/ServiceNow/SOAR) embedded in DetectionEvent metadata and upserted via case API.

### **MCP context (required) [Informative]**

mission\_id; role="SIEMAnalystAgent"; intent="detect"; constraints=["timebox\_2m"]; policy\_refs (e.g., SI-4, AU-6, IR-4); decision\_basis (evidence\_refs, confidence, explanation\_ref, mapping\_refs for ATT&CK); provenance (SPIFFE ID, signing KID, attestation)

### **MCP context (optional) [Informative]**

classification (C1–C3 by event sensitivity); legal\_hold (true when escalated); case\_ref (external case/alert identifier)

### **Enforcement note [Informative]**

Correlation pipelines and PEPs MUST enforce constraints=["timebox\_2m"] (drop or mark late events), validate MCP signature/provenance, require ATT&CK mapping\_refs for sev >= medium, and verify case\_ref ownership before mutate.

### **NIST SP 800-160v2 linkage [Informative]**

Anticipate & Withstand (early detection via correlation across diverse signals); Recover (fast case creation and linkage).

### **Automation feasibility [Informative]**

High (rule/ML-driven correlation and alert emission; case routing automated with HITL on high-impact or low-confidence detections).

---

## **Output Contracts (merged) [Informative]**

### **OC-1: DetectionEventPublish [Informative]**

- **Producer(s):** D2
- **Topic/Path:** Kafka secops.detections.v1, AMQP secops.detections.v1, REST POST /detections

- **Schema/Format:** DetectionEvent@1.1 (detection\_id, rule\_id, severity, confidence, tactic, technique, subtechnique, correlation\_keys[], asset, user, evidence\_refs[], mapping\_refs[], case\_ref?, created\_ts, ttl\_minutes)
- **Classification:** C1–C2 (C3 if contains sensitive payload refs)
- **Delivery:** at-least-once (stream), idempotent REST
- **Ordering:** per detection\_id
- **Idempotency-Key:** sha256(detection\_fingerprint, created\_ts\_floor\_10s)
- **Ack/Nack:** stream offset commit / HTTP 201; NACK on schema or timebox breach
- **Timeouts/Retry:** emit<=120s from first evidence\_ts; exp-backoff<=5x
- **Side-Effects:** increment detection counters; attach to suppression evaluation pipeline
- **HITL Token:** required only when sev>=high AND (CrownJewels OR confidence < theta\_auto)
- **Observability:** trace\_id, mission\_id, mapping\_refs, decision\_basis.\*, classification\_label, provenance.attestation
- **Retention/TTL:** ttl\_minutes (default 1440) or per legal\_hold

#### **Schema Capsule (OC-1) [Normative]**

**Requirement Level:** Required

**Condition:** Always

schema\_id=DetectionEvent@1.1 | json\_schema\_uri=uri://schema/detection-event-1.1.json | sha256= | producers=D2 | consumers=SIEM-01, SOAR-01, Case-01 | accepts=1.0–1.1

**Conformance:** Normative.

#### **OC-2: CaseLinkUpsert [Informative]**

- **Producer(s):** D2
- **Topic/Path:** REST POST /cases/upsert-link or direct platform APIs (TheHive/Jira/ServiceNow/SOAR)
- **Schema/Format:** CaseLink@1.0 (case\_ref, detection\_id, summary, severity, tags[], owner, status, href)
- **Classification:** C2+

- **Delivery:** exactly-once per (detection\_id)
- **Ordering:** per case\_ref
- **Idempotency-Key:** sha256(detection\_id)
- **Ack/Nack:** 200/201 with case\_ref; NACK on permissions or invalid state
- **Timeouts/Retry:** ack<=30s; exp-backoff<=5x; escalate to HITL on repeated NACK/timeouts
- **Side-Effects:** mirror essentials into DetectionEvent metadata; add evidence\_refs to case
- **HITL Token:** required for cases tied to CrownJewels
- **Observability:** trace\_id, mission\_id, case\_ref, decision\_basis.\*, provenance.attestation
- **Retention/TTL:** per IR retention policy (>= 1 year)

#### **Schema Capsule (OC-2) [Normative]**

**Requirement Level:** Conditionally Required

**Condition:** When a case management system is integrated or when sev>=medium  
 schema\_id=CaseLink@1.0 | json\_schema\_uri=uri://schema/case-link-1.0.json |  
 sha256= | producers=D2 | consumers=TheHive-01, Jira-01, SNOW-IR-01, SOAR-01 |  
 accepts=1.0

**Conformance:** Normative when condition is met.

#### **OC-3: DetectionFeedbackEvent (Stakeholder Feedback Loop) [Informative, optional]**

- **Producer(s):** SOC portal, D2 (aggregation)
- **Topic/Path:** secops.detections.feedback.v1
- **Schema/Format:** DetectionFeedback@1.0 (detection\_id, label={tp|fp|unknown}, rationale, operator\_id, timestamp)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per detection\_id
- **Idempotency-Key:** sha256(detection\_id, operator\_id, label)
- **Ack/Nack:** feedback\_id assigned; NACK on missing detection\_id
- **Side-Effects:** update suppression and learning queues; annotate case

- **HITL Token:** none
- **Observability:** trace\_id, mission\_id, label, operator\_id
- **Retention/TTL:** 1 year (or per HR/Legal)

### **Schema Capsule (OC-3) [Normative]**

**Requirement Level:** Optional

**Condition:** When stakeholder feedback workflow is enabled

schema\_id=DetectionFeedback@1.0 | json\_schema\_uri=uri://schema/detection-feedback-1.0.json | sha256= | producers=SOC-Portal-01, D2 | consumers=Det-ML-01, Governance-01 | accepts=1.0

**Conformance:** Normative if implemented or claimed.

### **State machine (concise) [Informative]**

states = { idle, ingesting, normalizing, correlating, mapping, scoring, emitting\_detection, case\_linking, contestation\_workflow, failed, closed }

transition(idle -> ingesting) when batch\_tick or event\_arrival

transition(ingesting -> normalizing) when schema validated

transition(normalizing -> correlating) when keys extracted (user|host|trace\_id|role)

transition(correlating -> mapping) when correlation window W closes or sufficient agreement reached

transition(mapping -> scoring) when ATT&CK mapping\_refs resolved

transition(scoring -> emitting\_detection) when severity/confidence computed and timebox<=120s

transition(emitting\_detection -> case\_linking) when sev>=medium or policy requires case linkage

transition(\* -> contestation\_workflow) on FP claim or mapping conflict

transition(\* -> failed) on schema/timebox violation

timeout(emitting\_detection, 120s) -> failed; retry<=5 with exp backoff

idempotency\_key = sha256(detection\_fingerprint, created\_ts\_floor\_10s)

### **Output Contracts Summary [Normative]**

| Output Contract                | Requirement Level             | Trigger Condition                          | Business Impact                         |
|--------------------------------|-------------------------------|--------------------------------------------|-----------------------------------------|
| OC-1<br>DetectionEventPublish  | <b>Required</b>               | Always                                     | Core alert distribution and correlation |
| OC-2 CaseLinkUpsert            | <b>Conditionally Required</b> | Case mgmt integrated OR severity >= medium | Investigation workflow linkage          |
| OC-3<br>DetectionFeedbackEvent | <b>Optional</b>               | Feedback workflow enabled                  | Continuous detection improvement        |

#### Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

---

#### Policies and HITL gates [Informative]

- policy\_refs: SI-4 (System Monitoring), AU-6 (Audit Review/Analysis), IR-4 (Incident Handling), SC-28 (Protection of Information at Rest)
- **HITL required:** sev>=high on CrownJewels; classification=C3; confidence<threshold; mapping\_conflict=true
- **Automatic HITL escalation triggers:** model\_drift\_detected=true; stakeholder\_disagreement\_score>=0.5; FP\_rate\_24h > threshold
- **Manual outside agent:** major incident declaration; law-enforcement coordination

#### SLOs and KPIs [Informative]

- DetectionEmitLatency\_p95 <= 120 s (from first evidence\_ts)
- CaseLinkAck\_p95 <= 30 s
- MappingAccuracy\_eval >= 99.0 percent
- FalsePositiveRate\_7d <= 2 percent

- DriftDetect\_MTTD <= 24 h

## Outputs index [Informative]

[OC-1 DetectionEventPublish], [OC-2 CaseLinkUpsert], [OC-3 DetectionFeedbackEvent]

---

## Technical Implementation Details (D2) [Informative]

### Model and training profile [Informative]

model\_id=siem-analyst-text; temperature=0.0; max\_tokens\_out=700  
 prompt\_pack\_id=siem-correlation-v1 (Sigma heuristics, ATT&CK mapping, severity rubric)  
 RAG: sources={detections-kb, attack-encyclopedia, suppression-history, asset-criticality}; max\_docs=12; min\_similarity=0.78; citations required  
 fine\_tuning/adapters: none initially; eval gates on mapping accuracy and hallucination bounds  
 guardrails: enforce constraints=["timebox\_2m"]; deny actions that mutate sources; scoped case API tokens

### Memory and state [Informative]

working\_memory.max\_tokens=4k; eviction=recency\_then\_importance  
 episodic\_memory: per mission\_id journal of detections and case links; ttl=365d  
 semantic\_memory: namespaces=["detections","attack","assets","suppression"];  
 embeddings=text-embedding-sec-v1; k=12  
 durable\_state\_store: event-sourced detection ledger; snapshot every 10k detections  
 consistency: at-least-once (detection); exactly-once (case link per detection\_id)  
 idempotency: per Output Contracts

### Decision and routing logic [Informative]

**Correlation window:** W = 5 minutes sliding; early emit if signal\_agreement >= theta\_agree.

**Severity (0–100) → {low, medium, high, critical}:**

severity\_score = 0.35\*asset\_criticality + 0.30\*signal\_agreement + 0.20\*behavior\_risk + 0.15\*(1 - fp\_history)

**Confidence (0–1):**

confidence = 0.5\*signal\_agreement + 0.3\*rule\_strength + 0.2\*(1 - fp\_history)

**Mapping conflict rule:** if multiple techniques tie and differ in tactic, mark conflict and send to HITL.

Routing: detections→bus/REST; if sev>=medium → case\_link; apply backpressure when queue\_depth > threshold.

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

## **Model Risk Management [Informative]**

continuous\_validation: daily golden set + adversarial event blends (mimic benign ops)  
thresholds: MappingAccuracy\_eval >= 99.0 percent; if drop >= 1.5 pp over 48 h → auto\_HITL, consider rollback  
red\_team\_cycle: monthly ATT&CK technique drift and rule-evasion trials  
rollback\_policy: revert model\_id on sustained eval drop

## **Transparency and Audit Trail (Approver/Auditor UX) [Informative]**

decision\_rationale\_template: who/what/why; evidence\_refs; mapping\_refs;  
severity/confidence math; hashes  
UI/API: expose classification\_label, provenance.attestation, decision\_rationale\_url  
audit\_log\_format: JSONL; retention per classification and legal\_hold

## **Incident Response Integration [Informative]**

CaseLinkUpsert to IR platforms; attach evidence\_refs; ensure bi-directional updates (status/owner) reflected in DetectionEvent updates.

## **Change Impact Assessment [Informative]**

Track rule changes vs. alert volume and FP/TP ratios; emit rollup metrics to governance dashboards.

## **Stakeholder Feedback Loop [Informative]**

Ingest FP/TP feedback via DetectionFeedbackEvent; suppress patterns after governance review; never auto-train directly on regulated telemetry.

## **Data Sovereignty and Legal Hold [Informative]**

Honor regional constraints; set legal\_hold=true when escalated to investigation; pause TTL/purge accordingly.

## **Interfaces (links only) [Informative]**

Consumes: OTel, EDR REST/Syslog/OTLP, IdP/IAM logs, CloudTrail/Azure/GCP Audit  
Produces: OC-1 DetectionEventPublish; OC-2 CaseLinkUpsert; OC-3 DetectionFeedbackEvent

## **Safety and abuse prevention [Informative]**

kill\_switch on timebox breach spikes; sandbox mapping when provenance missing; blast-radius caps on case creation; QPS/cost limits.

## **Testing and validation [Informative]**

Contract tests per Schema Capsules; offline replay of historical incidents; red-team mapping conflicts; drift checks and rollback.

### Deployment and lifecycle [Informative]

HPA on ingest/correlation queues; canary rule packs; SBOM + attestations; signed DetectionEvents.

---

### References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (SI-4, AU-6, IR-4, SC-28); NIST SP 800-61 Rev. 2; **OpenTelemetry** specification; **MITRE ATT&CK** (Enterprise); Sigma rules (Windows/Cloud/EDR).

---

### MCP-Native Protocol Specification (D2) [Normative]

- **Native Protocol(s) Consumed:** OTel Logs/Metrics/Traces; EDR Telemetry (REST/Syslog/OTLP); IdP/IAM Logs (REST/JSON/Syslog); Cloud Provider Logs (CloudTrail/Azure/GCP Audit)
- **Native Protocol(s) Produced:** DetectionEvent (Kafka/AMQP/REST); CaseLink upserts (TheHive/Jira/ServiceNow/SOAR REST)
- **MCP Context Fields:**
  - **Required:** mission\_id; role="SIEMAnalystAgent"; intent="detect"; constraints=["timebox\_2m"]; policy\_refs; decision\_basis (evidence\_refs, confidence, explanation\_ref, mapping\_refs); provenance (SPIFFE ID, signing KID, attestation)
  - **Optional:** classification; legal\_hold; case\_ref
- **Enforcement Note:** Pipelines MUST enforce timebox  $\leq 2$  minutes, validate signatures/provenance, require mapping\_refs for sev $\geq$ medium, and verify case\_ref ownership before mutation.
- **Versioning and compatibility; producers/consumers registry:** authoritative here; see Schema Capsules for accepted ranges/EOL dates.
- **Example payloads:** native and MCP-wrapped (authoritative, mirrored from Agent Blueprint).
- **Transparency hooks:** classification\_label, provenance.attestation, decision\_rationale\_url exposed to downstream UIs/APIs.

**Conformance:** This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

## D3. UEBA Analysis Agent

### Agent Blueprint [Informative]

**Purpose:** Detect behavior anomalies for identities and devices. Emit **AuthAnomaly** and high-fidelity **DetectionEvent** with explainability and ATT&CK mapping when applicable.

### Operational Narrative [Informative]

#### Inputs used (authoritative sources):

- **IdP/IAM Authentication Logs** — sign-in results, MFA, device/app, geo/asn/ip, principal type.
- **Device Graph (MDM/EDR/CMDB)** — device posture, ownership, OS/agent versions, user↔device links.
- **NetFlow/IPFIX/VPC Flow** — external ASN novelty, destinations, bytes/conn cadence, lateral movement hints.
- **HRIS Context** — employment type, org unit, manager, location, on-call status, recent role change.

#### Model training / knowledge (what the LLM relies on):

- Prompt pack for **UEBA features** (impossible travel, device posture, geo-velocity, ASN novelty, off-hours), severity rubric, and ATT&CK mapping hints (TA0006, TA0005, etc.).
- RAG sources: identity graph, device posture history, historical baselines per user/team/role, FP/TP history; do **not** train on regulated telemetry—fetch via `evidence_refs`.
- Guardrails: read-only scopes for logs/graphs; **constraints must include** `hitl_for_human_principals` and `risk_threshold:<score>`; deny any enforcement API calls (recommendations only).

#### Decisions it makes (deterministic + model-assisted):

- Compute **risk\_score (0–100)** per principal/session and per device, with contribution from geo-velocity, posture noncompliance, new ASN, off-hours, recent role change, and peer/role baselines.

- Emit **AuthAnomaly** when `risk_score >= risk_threshold` or when any “hard” predicate triggers (e.g., `impossible_travel` & `noncompliant_device`).
- When sufficient corroboration exists (e.g., flows + posture + auth anomaly) produce **DetectionEvent** with ATT&CK mapping (e.g., T1078 Valid Accounts) and push/link a case.
- Choose **classification** C2→C3 based on PII/HR fields present.

#### Routing / where outputs go:

- **AuthAnomaly** → Kafka/AMQP topic `secops.ueba.auth_anomaly.v1` and/or REST `/ueba/anomaly`.
- **DetectionEvent** → `secops.detections.v1` (Kafka/AMQP/REST) with optional **case\_ref** to TheHive/Jira/ServiceNow/SOAR.
- **Tickets/alerts** → opened when HITL is required or SLA/timebox is breached.

#### Automation scope vs. manual/HITL:

- Fully automated: feature extraction, scoring, baseline updates, AuthAnomaly emission, low-impact DetectionEvents for service principals.
- **HITL required:** any anomaly involving **human principals** (per constraints), or **CrownJewels** access, or `classification=C3`, or `confidence < theta_auto`.
- Manual outside agent: HR/legal escalations, workforce comms, major incident declaration.

---

**Security Domain:** Threat Intelligence, Situational Awareness, and Monitoring

#### Inputs (native protocols consumed) [Informative]

##### 1. IdP/IAM Authentication Logs (REST/Syslog/OTLP)

Native payload

```
{
  "event_id": "signin-42aa",
  "user": "E104201",
  "principal_type": "human",
  "app": "vpn",
  "client": "AnyConnect",
```

```

"ip": "203.0.113.44",
"asn": "AS64500",
"geo": "DE-BE",
"device_id": "dev-8c77",
"time": "2025-08-15T14:02:11Z",
"decision": "allow",
"risk_signals": ["impossible_travel", "new_device"]
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-d3-ueba-1111-2222-3333-4444",
    "thread_id": "uuid-auth-E104201-2025-08-15T14:02:11Z",
    "task_id": "uuid-a1b2-c3d4-e5f6-7788",
    "role": "UEBAAnalysisAgent",
    "intent": "detect",
    "constraints": ["hitl_for_human_principals", "risk_threshold:75"],
    "policy_refs": ["SI-4", "AU-6", "IA-2", "AC-7"],
    "decision_basis": {
      "evidence_refs": ["uri://idp/signin/signin-42aa"],
      "confidence": 0.88,
      "explanation_ref": "uri://models/ueba/v1/impossible-travel"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/threat/ueba-analysis-agent",
      "signing_kid": "kid-idp-d3-01",

```

```

    "attestation_ref": "uri://slsa/attestations/ueba@sha256:idp01"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { ... }
}

```

## 2. Device Graph (MDM/EDR/CMDB) via REST/GraphQL

Native payload

```

{
  "device_id": "dev-8c77",
  "user_employee_id": "E104201",
  "platform": "Windows",
  "os_version": "11.0.26100",
  "compliance": "noncompliant",
  "reasons": ["secure_boot_disabled"],
  "edr_sensor": "7.3.2",
  "last_checkin": "2025-08-15T13:58:40Z",
  "owned_by": "corp"
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-d3-device-5555-6666-7777-8888",
    "thread_id": "uuid-device-dev-8c77",
    "task_id": "uuid-9911-8822-7733-6644",

```

```

"role": "UEBAAnalysisAgent",
"intent": "detect",
"constraints": ["hitl_for_human_principals", "risk_threshold:75"],
"policy_refs": ["CM-6", "IA-2", "SI-4"],
"decision_basis": {
  "evidence_refs": ["uri://mdm/devices/dev-8c77"],
  "confidence": 0.9,
  "explanation_ref": "uri://kb/ueba/features#device-posture-weighting"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/threat/ueba-analysis-agent",
  "signing_kid": "kid-mdm-d3-02",
  "attestation_ref": "uri://slsa/attestations/ueba@sha256:mdm02"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { ... }
}

```

### 3. NetFlow/IPFIX/VPC Flow (REST/OTLP)

Native payload

```

{
  "timestamp": "2025-08-15T14:01:58Z",
  "src_ip": "10.22.9.41",
  "src_device_id": "dev-8c77",
  "dst_ip": "198.51.100.77",
  "dst_port": 443,

```

```
"proto": "TCP",
"bytes": 184320,
"connections_last_24h": 1,
"new_external_asn": true
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-d3-flow-aaaa-bbbb-cccc-dddd",
    "thread_id": "uuid-flow-dev-8c77-198.51.100.77",
    "task_id": "uuid-1122-3344-5566-7788",
    "role": "UEBAAnalysisAgent",
    "intent": "detect",
    "constraints": ["hitl_for_human_principals", "risk_threshold:75"],
    "policy_refs": ["SI-4", "SC-7"],
    "decision_basis": {
      "evidence_refs": ["uri://flows/dev-8c77/2025-08-15T14:01:58Z"],
      "confidence": 0.86,
      "explanation_ref": "uri://kb/ueba/features#new-external-asn"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/threat/ueba-analysis-agent",
      "signing_kid": "kid-flow-d3-03",
      "attestation_ref": "uri://slsa/attestations/ueba@sha256:flow03"
    },
    "classification": "C2",
  }
}
```

```
"legal_hold": false
},
"native_payload": { ... }
}
```

#### 4. HR Context (HRIS REST)

Native payload

```
{
  "employee_id": "E104201",
  "employment_type": "FTE",
  "department": "Payments Engineering",
  "manager_employee_id": "E100014",
  "oncall_now": false,
  "location": "NYC",
  "last_role_change": "2025-07-30"
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-d3-hr-7777-8888-9999-0000",
    "thread_id": "uuid-hr-E104201",
    "task_id": "uuid-abcd-ef01-2345-6789",
    "role": "UEBAAnalysisAgent",
    "intent": "detect",
    "constraints": ["hitl_for_human_principals", "risk_threshold:75"],
    "policy_refs": ["PM-12", "SI-4"],
    "decision_basis": {
```

```

    "evidence_refs": ["uri://hris/employees/E104201"],
    "confidence": 0.93,
    "explanation_ref": "uri://kb/ueba/context#role-and-oncall"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/threat/ueba-analysis-agent",
    "signing_kid": "kid-hr-d3-04",
    "attestation_ref": "uri://slsa/attestations/ueba@sha256:hr04"
  },
  "classification": "C3",
  "legal_hold": false
},
"native_payload": { ... }
}

```

### Outputs (native) [Informative]

- **AuthAnomaly** (Kafka/AMQP/REST).
- **DetectionEvent** (Kafka/AMQP/REST) with ATT&CK tags and optional case links.

### MCP context (required) [Informative]

mission\_id; role="UEBAAnalysisAgent"; intent="detect"; constraints includes hitl\_for\_human\_principals and risk\_threshold:<score>; policy\_refs (e.g., SI-4, AU-6, IA-2, AC-7); decision\_basis (evidence\_refs, confidence, explanation\_ref); provenance (SPIFFE ID, signing KID, attestation)

### MCP context (optional) [Informative]

classification (C2–C3); legal\_hold (true when routed to investigation); case\_ref

### Enforcement note [Informative]

Adaptive-auth PEPs and SOC tooling MUST verify signature/provenance, honor **HITL requirement for human principals**, and enforce **risk\_threshold** policies before any automated containment; DetectionEvent must include ATT&CK mapping when sev ≥ medium.

## **NIST SP 800-160v2 linkage [Informative]**

Anticipate & Withstand (early anomaly detection on identity/device graphs); Recover (rapid escalation and containment triggers).

## **Automation feasibility [Informative]**

High (feature extraction/scoring automated; HITL gates protect human principals and high-impact actions).

---

## **Output Contracts (merged) [Informative]**

### **OC-1: AuthAnomalyPublish [Informative]**

- **Producer(s):** D3
- **Topic/Path:** Kafka secops.ueba.auth\_anomaly.v1, AMQP secops.ueba.auth\_anomaly.v1, REST POST /ueba/anomaly
- **Schema/Format:** AuthAnomaly@1.1 (anomaly\_id, principal, principal\_type, device\_id?, geo, asn, risk\_score, features[], baseline\_refs[], evidence\_refs[], confidence, explanation\_ref, created\_ts, classification)
- **Classification:** C2–C3
- **Delivery:** at-least-once (stream), idempotent REST
- **Ordering:** per principal
- **Idempotency-Key:** sha256(principal, created\_ts\_floor\_5m, feature\_hash)
- **Ack/Nack:** offset commit / HTTP 201; NACK on schema or missing required features
- **Timeouts/Retry:** emit<=120s from first evidence\_ts; exp-backoff<=5x
- **Side-Effects:** update UEBA ledger; trigger advisory in IdP portal
- **HITL Token:** required if principal\_type = human AND risk\_score >= risk\_threshold
- **Observability:** trace\_id, mission\_id, decision\_basis.\*, classification\_label, provenance.attestation
- **Retention/TTL:** 30 days (extend if legal\_hold)

### **Schema Capsule (OC-1) [Normative]**

**Requirement Level:** Required

**Condition:** Always

schema\_id=AuthAnomaly@1.1 | json\_schema\_uri=uri://schema/auth-anomaly-1.1.json | sha256= | producers=D3 | consumers=SIEM-01, IdP-Console-01 | accepts=1.0–1.1

**Conformance:** Normative.

---

## OC-2: UEBA-DetectionEventPublish [Informative]

- **Producer(s):** D3
- **Topic/Path:** Kafka/AMQP secops.detections.v1, REST POST /detections
- **Schema/Format:** DetectionEvent@1.1 (detection\_id, severity, confidence, tactic, technique, subtechnique?, correlation\_keys[], principal, device\_id, evidence\_refs[], explanation\_ref, mapping\_refs[], case\_ref?, created\_ts, ttl\_minutes)
- **Classification:** C2–C3
- **Delivery:** at-least-once (stream), idempotent REST
- **Ordering:** per detection\_id
- **Idempotency-Key:** sha256(detection\_fingerprint, created\_ts\_floor\_10s)
- **Ack/Nack:** 201/offset commit; NACK on schema/timebox breach
- **Timeouts/Retry:** emit<=120s from first evidence\_ts; exp-backoff<=5x
- **Side-Effects:** open/link case when sev>=medium; annotate with baseline deltas
- **HITL Token:** required when principal\_type=human AND (sev>=high OR confidence<threshold)
- **Observability:** trace\_id, mission\_id, mapping\_refs, decision\_basis.\*, classification\_label, provenance.attestation
- **Retention/TTL:** ttl\_minutes (default 1440) or per legal\_hold

## Schema Capsule (OC-2) [Normative]

**Requirement Level:** Conditionally Required

**Condition:** When ATT&CK mapping is available OR organizational policy requires case linkage for anomalies above threshold

schema\_id=DetectionEvent@1.1 | json\_schema\_uri=uri://schema/detection-event-1.1.json | producers=D3 | consumers=SIEM-01, SOAR-01, Case-01 | accepts=1.0–1.1

**Conformance:** Normative when condition is met.

---

### OC-3: UEBAFeedbackEvent (Stakeholder Feedback Loop) [Informative, optional]

- **Producer(s):** SOC portal, D3 (aggregation)
- **Topic/Path:** secops.ueba.feedback.v1
- **Schema/Format:** UEBAFeedback@1.0 (anomaly\_or\_detection\_id, label={tp|fp|benign\_risk|unknown}, rationale, operator\_id, timestamp)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per anomaly\_or\_detection\_id
- **Idempotency-Key:** sha256(id, operator\_id, label)
- **Ack/Nack:** feedback\_id assigned; NACK on missing id
- **Side-Effects:** update baselines and suppression queues (governance-reviewed)
- **HITL Token:** none
- **Observability:** trace\_id, mission\_id, label, operator\_id
- **Retention/TTL:** 1 year (or per HR/Legal)

#### Schema Capsule (OC-3) [Normative]

**Requirement Level:** Optional

**Condition:** When feedback workflow is enabled

schema\_id=UEBAFeedback@1.0 | json\_schema\_uri=uri://schema/ueba-feedback-1.0.json | producers=SOC-Portal-01, D3 | consumers=UEBA-ML-01, Governance-01 | accepts=1.0

**Conformance:** Normative if implemented or claimed.

---

#### State machine (concise) [Informative]

states = { idle, ingesting, featurizing, scoring, correlating, emit\_auth\_anomaly, emit\_detection, case\_linking, contestation\_workflow, failed, closed }  
transition(idle -> ingesting) when event\_arrival or schedule\_tick  
transition(ingesting -> featurizing) when schema validated  
transition(featurizing -> scoring) when features extracted (geo\_velocity, device\_posture, asn\_novelty, off\_hours, role\_delta, peer\_baseline\_delta)  
transition(scoring -> emit\_auth\_anomaly) when risk\_score >= risk\_threshold  
transition(scoring -> correlating) when corroborating signals present  
transition(correlating -> emit\_detection) when ATT&CK mapping resolved AND confidence >= theta\_map  
transition(emit\_detection -> case\_linking) when sev>=medium or policy requires

transition(\* -> contestation\_workflow) on FP claim or stakeholder\_disagreement\_score  
 >= 0.5  
 transition(\* -> failed) on schema/timebox violation  
 timeout(emit\_auth\_anomaly, 120s) -> failed; retry<=5  
 idempotency\_key = sha256(principal, created\_ts\_floor\_5m, feature\_hash) for  
 anomalies; sha256(detection\_fingerprint, created\_ts\_floor\_10s) for detections

---

### Output Contracts Summary [Normative]

| Output Contract                     | Requirement Level                 | Trigger Condition                                                                         | Business Impact                             |
|-------------------------------------|-----------------------------------|-------------------------------------------------------------------------------------------|---------------------------------------------|
| OC-1<br>AuthAnomalyPublish          | <b>Required</b>                   | Always                                                                                    | Core UEBA<br>anomaly<br>distribution        |
| OC-2 UEBA-<br>DetectionEventPublish | <b>Conditionally<br/>Required</b> | ATT&CK mapping<br>available or policy<br>requires case linkage<br>for high-risk anomalies | Case-ready high-<br>fidelity detections     |
| OC-3<br>UEBAFeedbackEvent           | <b>Optional</b>                   | Feedback workflow<br>enabled                                                              | Continuous<br>model/baseline<br>improvement |

### Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

---

### Policies and HITL gates [Informative]

- **policy\_refs:** SI-4, AU-6, IA-2, AC-7 (+ CM-6 for device posture), PM-12 for HR context.
- **HITL required:** principal\_type=human AND (risk\_score >= risk\_threshold OR sev>=high OR classification=C3 OR confidence<threshold).
- **Automatic HITL escalation:** model\_drift\_detected=true;  
stakeholder\_disagreement\_score>=0.5; FP\_rate\_7d > threshold.

- **Manual outside agent:** HR/legal actions; enterprise communications.

### **SLOs and KPIs [Informative]**

- AnomalyEmitLatency\_p95 <= 120 s
- DetectionEmitLatency\_p95 <= 120 s
- HITLMedianDecisionTime <= 30 min
- FP\_Rate\_7d <= 3 percent
- DriftDetect\_MTTD <= 24 h

### **Outputs index [Informative]**

[OC-1 AuthAnomalyPublish], [OC-2 UEBA-DetectionEventPublish], [OC-3 UEBAFeedbackEvent]

---

## **Technical Implementation Details (D3) [Informative]**

### **Model and training profile [Informative]**

model\_id=ueba-analysis-text; temperature=0.0; max\_tokens\_out=700  
 prompt\_pack\_id=ueba-v1 (features, rubric, ATT&CK hints, HITL rules)  
 RAG: sources={identity-graph, device-posture-history, baselines, fp-tp-history};  
 max\_docs=12; min\_similarity=0.78; citations required  
 fine\_tuning/adapters: none initially; eval on feature extraction accuracy and hallucination bounds  
 guardrails: enforce hitl\_for\_human\_principals; block any direct enforcement calls

### **Memory and state [Informative]**

working\_memory.max\_tokens=4k; eviction=recency\_then\_importance  
 episodic\_memory: per mission\_id journal of anomalies/detections; ttl=365d  
 semantic\_memory: namespaces=["identities","devices","baselines","hr"];  
 embeddings=text-embedding-sec-v1; k=12  
 durable\_state\_store: event-sourced UEBA ledger; snapshot daily  
 consistency: at-least-once (anomaly/detection)  
 idempotency: per Output Contracts

### **Decision and routing logic [Informative]**

#### **Feature normalization:**

- geo\_velocity\_kmh, asn\_novelty in {0,1}, off\_hours in {0,1}, posture in {0,1} (1=noncompliant),

- role\_delta in {0,1}, peer\_delta\_z (z-score vs. peer baseline), flow\_asn\_novelty in {0,1}.

#### **Risk score (0–100):**

risk\_score = 100 \* (0.25\*geo\_velocity\_norm + 0.20\*posture + 0.15\*asn\_novelty + 0.15\*off\_hours + 0.10\*role\_delta + 0.15\*peer\_delta\_norm)

where geo\_velocity\_norm = min(1, geo\_velocity\_kmh / 900) and peer\_delta\_norm = min(1, abs(peer\_delta\_z) / 4).

#### **Confidence (0–1):**

confidence = 0.5\*signal\_agreement + 0.3\*(1 - fp\_history) + 0.2\*data\_quality

#### **Hard predicates:**

- impossible\_travel = true AND posture=1 → emit AuthAnomaly regardless of score.
- new\_external\_asn=true AND peer\_delta\_z >= 3 → raise severity.

#### **ATT&CK mapping (examples):**

- T1078 (Valid Accounts) for unusual but successful auth with corroborating flows.
- T1556.\* (Modify Auth Process) for MFA anomalies with config changes.
- T1021 (Remote Services) when anomalous lateral movement patterns appear.

Routing: anomalies→bus/REST; detections→bus/REST; case linkage when sev>=medium or policy requires.

#### **Model Risk Management [Informative]**

continuous\_validation: daily golden set + adversarial synthetic sessions (VPN hop, ASN churn)

thresholds: AUC >= 0.98, FPR@operating\_point <= 0.03 → else auto\_HITL and alert owners

red\_team\_cycle: monthly (geo-spoof, device posture evasions)

rollback\_policy: revert model\_id on eval\_drop >= 1.5 pp for 48 h

#### **Transparency and Audit Trail (Approver/Auditor UX) [Informative]**

decision\_rationale\_template: principal, session facts, features with weights, equations, ATT&CK mapping, evidence\_refs, hashes

UI/API: expose classification\_label, provenance.attestation, decision\_rationale\_url

audit\_log\_format: JSONL; retention bound to classification and legal\_hold

#### **Incident Response Integration [Informative]**

On sev>=medium, create/link case (CaseLinkUpsert via D2 pipeline or platform API), include baseline deltas and feature table.

### **Change Impact Assessment [Informative]**

Track threshold changes vs. alert volume and FP/TP; emit rollups to governance dashboards.

### **Stakeholder Feedback Loop [Informative]**

Ingest UEBAFeedbackEvent; adjust baselines/features after governance review; never auto-train on regulated telemetry.

### **Data Sovereignty and Legal Hold [Informative]**

Honor regional constraints; classification C3 when HR fields present; legal\_hold=true freezes TTLs.

### **Interfaces (links only) [Informative]**

Consumes: IdP/IAM logs; Device Graph; NetFlow/IPFIX/VPC Flow; HRIS  
Produces: OC-1 AuthAnomalyPublish; OC-2 UEBA-DetectionEventPublish; OC-3 UEBAFeedbackEvent

### **Safety and abuse prevention [Informative]**

kill\_switch on timebox breach spikes or provenance failure; sandbox on missing HITL token for human principals; rate-limit anomaly outputs.

### **Testing and validation [Informative]**

Contract tests per Schema Capsules; offline replay (auth + device + flow); red-team geo-velocity/ASN spoof; drift checks with rollback.

### **Deployment and lifecycle [Informative]**

HPA on ingest/feature queues; canary threshold updates; SBOM + attestations; sign all outputs.

---

### **References / Standards [Informative]**

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (SI-4, AU-6, IA-2, AC-7, CM-6); NIST SP 800-61 Rev. 2; MITRE ATT&CK/D3FEND; OpenTelemetry; CIS v8.

---

## MCP-Native Protocol Specification (D3) [Normative]

- **Native Protocol(s) Consumed:** IdP/IAM Auth Logs (REST/Syslog/OTLP); Device Graph (MDM/EDR/CMDB REST/GraphQL); NetFlow/IPFIX/VPC Flow (REST/OTLP); HRIS (REST)
- **Native Protocol(s) Produced:** AuthAnomaly (Kafka/AMQP/REST); DetectionEvent (Kafka/AMQP/REST)
- **MCP Context Fields:**
  - **Required:** mission\_id; role="UEBAAAnalysisAgent"; intent="detect"; constraints includes hitl\_for\_human\_principals and risk\_threshold:<score>; policy\_refs; decision\_basis (evidence\_refs, confidence, explanation\_ref); provenance (SPIFFE ID, signing KID, attestation)
  - **Optional:** classification (C2–C3); legal\_hold; case\_ref
- **Enforcement Note:** Downstream PEPs and SOC tools MUST validate signature/provenance, enforce HITL for human principals, and respect risk\_threshold before any automated action. ATT&CK mapping is required for sev≥medium DetectionEvents.
- **Versioning and compatibility; producers/consumers registry:** authoritative here; see Schema Capsules for accepted ranges/EOL.
- **Example payloads:** native and MCP-wrapped (authoritative, mirrored from Agent Blueprint).
- **Transparency hooks:** classification\_label, provenance.attestation, decision\_rationale\_url exposed to UIs/APIs.

**Conformance:** This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

## D4. Autonomous Hunter Agent

### Agent Blueprint [Informative]

**Purpose:** Conduct proactive hunts and ATT&CK emulations. Convert hypotheses into targeted queries, pivot across telemetry, and emit high-fidelity **DetectionEvent** with reproducible **HuntNotebook** artifacts.

### Operational Narrative [Informative]

**Inputs used (authoritative sources):**

- **SIEM / UEBA Feature Stream (REST/OTLP/Query API)** — entity windows, feature vectors (e.g., encoded-PowerShell rate, ASN novelty), candidate TTP hints.
- **Intel Hypotheses (REST/Git)** — scoped hypotheses with TTP chains, prebuilt queries (Sigma/KQL/etc.), and (sandboxed) emulation atoms.

### Model training / knowledge (what the LLM relies on):

- Prompt pack for **hunt planning** (hypothesis triage → query selection → pivot strategy), ATT&CK mapping, and evidence quality scoring.
- RAG sources: detections/rules catalog, ATT&CK/D3FEND encyclopedia, historical hunts + outcomes, environment topology (entities, tags), and FP/TP history. Do **not** train on regulated telemetry—fetch via evidence\_refs.
- Guardrails: **read-only** on production data planes; emulation restricted by **constraints** sandbox\_only; scoped tokens for SIEM query APIs and object storage/Git for artifacts.

### Decisions it makes (deterministic + model-assisted):

- **Hypothesis triage** → rank by coverage gaps, entity risk, and recent intel.
- **Query selection & pivot plan** → choose rules/dialects; expand with entity-aware filters; iterate until confidence converges or budget/timebox expires.
- **Finding qualification** → compute finding\_confidence, attach ATT&CK mapping(s), decide if a **DetectionEvent** should be emitted and whether to open/link a case.
- **Artifact capture** → assemble a **HuntNotebook** that reproduces steps, queries, parameters, results samples, and conclusions.

### Routing / where outputs go:

- **DetectionEvent** → Kafka/AMQP topic secops.detections.v1 and optional REST /detections; includes mapping\_refs, evidence\_refs, case\_ref.
- **HuntNotebook** → object storage (versioned) or Git (PR with rendered markdown + notebook file); index entry to hunt catalog.

### Automation scope vs. manual/HITL:

- Fully automated: hypothesis triage, query/pivot execution, confidence scoring, notebook assembly and publish.

- **HITL required:** any **emulation** (must be `sandbox_only`), any production-impacting recommendation, and any `DetectionEvent` that would trigger CrownJewels playbooks or has confidence < `theta_auto`.
- Manual outside agent: purple-team design, new data source onboarding, inter-team campaign retros.

---

**Security Domain:** Threat Intelligence, Situational Awareness, and Monitoring

**Inputs (native protocols consumed) [Informative]**

1. **SIEM or UEBA Feature Stream (REST/OTLP/Query API)** — entity-window feature vectors & candidate TTPs.

**Native payload**

```
{
  "feature_window_start": "2025-08-15T13:50:00Z",
  "feature_window_end": "2025-08-15T14:05:00Z",
  "entity_type": "host",
  "entity_id": "WIN-SRV-02",
  "features": {
    "proc_powershell_encoded_rate_p95": 0.97,
    "websvc_to_powershell_transition_count": 4,
    "scriptblock_entropy_mean": 6.8,
    "new_external_asn_connections": 2,
    "admin_logon_after_service_spawn": 1
  },
  "candidate_ttp": ["T1059.001", "T1105"]
}
```

**MCP-wrapped payload**

```
{
  "mcp_context": {
    "mcp_version": "0.9",
```

```

"mission_id": "uuid-d4-hunt-1111-2222-3333-4444",
"thread_id": "uuid-entity-WIN-SRV-02-2025-08-15T13:50:00Z",
"task_id": "uuid-a1b2-c3d4-e5f6-7788",
"role": "AutonomousHunterAgent",
"intent": "hunt",
"constraints": ["sandbox_only"],
"policy_refs": ["SI-4", "AU-6", "IR-4", "NIST-800-115"],
"decision_basis": {
  "evidence_refs": ["uri://siem/features/WIN-SRV-02/2025-08-15T13:50:00Z_14:05:00Z"],
  "mapping_refs": ["ATT&CK:T1059.001", "ATT&CK:T1105"],
  "confidence": 0.9,
  "explanation_ref": "uri://kb/hunting/feature-to-ttp-weighting"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/threat/autonomous-hunter-agent",
  "signing_kid": "kid-siem-d4-01",
  "attestation_ref": "uri://slsa/attestations/autonomous-hunter@sha256:siem01"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { ... }
}

```

## 2. Intel Hypotheses (REST/Git) — scoped hunts, queries, and optional sandbox emulations.

### Native payload

```
{
```

```

    "hypothesis_id": "HYP-2025-0815-0012",
    "name": "Webshell to encoded PowerShell to data staging",
    "scope": {"entity_type": "host", "tag_any": ["iis", "internet_facing"]},
    "ttp_chain": ["T1505.003", "T1059.001", "T1074"],
    "hunt_queries": [
      {"dialect": "Sigma", "id": "sigma-win-powershell-encoded"},
      {"dialect": "KQL", "text": "DeviceProcessEvents | where Process has 'powershell' and CommandLine has '-enc'"}
    ],
    "emulation": {
      "toolkit": "AtomicRedTeam",
      "atoms": ["T1059.001-Windows-Run-PowerShell-EncodedCommand"],
      "preconditions": ["sandbox_network_isolation", "snapshot_taken"]
    }
  }
}

```

### **MCP-wrapped payload**

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-d4-hyp-5555-6666-7777-8888",
    "thread_id": "uuid-hyp-HYP-2025-0815-0012",
    "task_id": "uuid-9911-8822-7733-6644",
    "role": "AutonomousHunterAgent",
    "intent": "hunt",
    "constraints": ["sandbox_only"],
    "policy_refs": ["SI-4", "IR-4", "NIST-800-115"],
    "decision_basis": {

```

```

    "evidence_refs": ["uri://git/hypotheses/HYP-2025-0815-0012.json"],
    "mapping_refs": ["ATT&CK:T1505.003", "ATT&CK:T1059.001", "ATT&CK:T1074"],
    "confidence": 0.95,
    "explanation_ref": "uri://kb/hunting/hypothesis-triage"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/threat/autonomous-hunter-agent",
    "signing_kid": "kid-hyp-d4-02",
    "attestation_ref": "uri://slsa/attestations/autonomous-hunter@sha256:hyp02"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { ... }
}

```

### Outputs (native) [Informative]

- **DetectionEvent** (Kafka/AMQP/REST) with ATT&CK mapping, confidence, evidence\_refs, and optional **case\_ref**.
- **HuntNotebook** (object storage or Git) — reproducible notebook (steps, queries, parameters, results snapshots, findings) with digest and provenance.

### MCP context (required) [Informative]

mission\_id; role="AutonomousHunterAgent"; intent="hunt"; **constraints includes sandbox\_only** for emulations; policy\_refs (e.g., SI-4, AU-6, IR-4, NIST-800-115); decision\_basis (evidence\_refs, confidence, explanation\_ref, mapping\_refs?); provenance (SPIFFE ID, signing key, attestation)

### MCP context (optional) [Informative]

classification (C1–C3); legal\_hold (true when escalated); case\_ref (IR tooling linkage)

### Enforcement note [Informative]

PEPs MUST ensure **read-only** access on production data; any **emulation** MUST verify constraints contains sandbox\_only and attestation of sandbox isolation; DetectionEvents impacting CrownJewels or with low confidence require HITL token before auto-routing to containment playbooks.

### **NIST SP 800-160v2 linkage [Informative]**

Anticipate & Withstand via proactive discovery/validation of attack paths; Recover via reproducible evidence and rapid case linkage. (Emulation practices align with **NIST SP 800-115**.)

### **Automation feasibility [Informative]**

High (triage→pivot→notebook generation fully automatable; HITL for sensitive actions/emulations).

---

## **Output Contracts (merged) [Informative]**

### **OC-1: Hunter-DetectionEventPublish [Informative]**

- **Producer(s):** D4
- **Topic/Path:** Kafka secops.detections.v1; AMQP secops.detections.v1; REST POST /detections
- **Schema/Format:** DetectionEvent@1.1 (detection\_id, rule\_or\_hypothesis\_id, severity, confidence, tactic, technique, subtechnique?, correlation\_keys[], entity, evidence\_refs[], mapping\_refs[], case\_ref?, created\_ts, ttl\_minutes)
- **Classification:** C1–C2 (C3 if sensitive entity context embedded)
- **Delivery:** at-least-once (stream); idempotent REST
- **Ordering:** per detection\_id
- **Idempotency-Key:** sha256(detection\_fingerprint, created\_ts\_floor\_10s)
- **Ack/Nack:** 201/offset commit; NACK on schema/timebox violation
- **Timeouts/Retry:** emit≤120s from first evidence\_ts; exp-backoff≤5x
- **Side-Effects:** upsert case link when sev≥medium; annotate with hypothesis refs
- **HITL Token:** required for CrownJewels or confidence<threshold
- **Observability:** trace\_id, mission\_id, mapping\_refs, decision\_basis.\*, classification\_label, provenance.attestation

- **Retention/TTL:** ttl\_minutes (default 1440) or per legal\_hold

#### **Schema Capsule (OC-1)** [Normative]

**Requirement Level:** Conditionally Required

**Condition:** When a hunt yields a validated finding (confidence >= theta\_emit)  
 schema\_id=DetectionEvent@1.1 | json\_schema\_uri=uri://schema/detection-event-1.1.json | sha256= | producers=D4 | consumers=SIEM-01, SOAR-01, Case-01 |  
 accepts=1.0–1.1

**Conformance:** Normative when condition is met.

#### **OC-2: HuntNotebookPublish** [Informative]

- **Producer(s):** D4
- **Topic/Path:** s3://hunt-notebooks/<date>/<hunt\_id>.ipynb and/or Git sec/hunts/<hunt\_id>/ (notebook + README.md)
- **Schema/Format:** HuntNotebook@1.0 (hunt\_id, hypothesis\_id?, scope, steps[], queries[], parameters, sample\_results\_refs[], findings\_summary, env\_digest, tool\_versions, provenance.attestation, notebook\_uri, rendered\_md\_uri)
- **Classification:** C1–C2 (C3 if sensitive samples included)
- **Delivery:** exactly-once per hunt\_id (object version or Git commit digest)
- **Ordering:** per hunt\_id
- **Idempotency-Key:** sha256(hunt\_id, env\_digest, steps\_digest)
- **Ack/Nack:** 201 Created (object/Git commit) = ACK; NACK on validation or write failure
- **Timeouts/Retry:** ack<=60s; exp-backoff<=5x; dead-letter to hunts.publish.dlq
- **Side-Effects:** index entry in hunt catalog; link from DetectionEvent (if any)
- **HITL Token:** none (artifact only)
- **Observability:** trace\_id, mission\_id, hypothesis\_id, evidence\_refs, decision\_basis.\*, provenance.attestation
- **Retention/TTL:** 7 years (or per legal\_hold)

#### **Schema Capsule (OC-2)** [Normative]

**Requirement Level:** Required

**Condition:** Always

schema\_id=HuntNotebook@1.0 | json\_schema\_uri=uri://schema/hunt-notebook-

1.0.json | sha256= | producers=D4 | consumers=Hunt-Catalog-01, Auditors-01 |  
accepts=1.0

**Conformance:** Normative.

---

### State machine (concise) [Informative]

states = { idle, triaging\_hypotheses, planning, querying, pivoting, evaluating,  
emitting\_detection, publishing\_notebook, contestation\_workflow, failed, closed }  
transition(idle -> triaging\_hypotheses) when features\_or\_hypothesis\_arrival  
transition(triaging\_hypotheses -> planning) when top-K selected  
transition(planning -> querying) when queries compiled  
transition(querying -> pivoting) when partial evidence found OR plan requires additional  
signals  
transition(pivoting -> evaluating) when pivots complete  
transition(evaluating -> emitting\_detection) when confidence >= theta\_emit AND  
mapping\_refs resolved  
transition(evaluating -> publishing\_notebook) when hunt completes (finding or no-  
finding)  
transition(\* -> contestation\_workflow) on FP claim or stakeholder\_disagreement\_score  
>= 0.5  
transition(\* -> failed) on schema/timebox/emulation-policy violation  
timeout(publishing\_notebook, 60s) -> failed; retry<=5  
idempotency\_key = sha256(hunt\_id, env\_digest, steps\_digest)

---

### Output Contracts Summary [Normative]

| Output Contract                       | Requirement Level                 | Trigger Condition                                           | Business Impact                               |
|---------------------------------------|-----------------------------------|-------------------------------------------------------------|-----------------------------------------------|
| OC-2<br>HuntNotebookPublish           | <b>Required</b>                   | Always                                                      | Reproducibility,<br>audit trail,<br>knowledge |
| OC-1 Hunter-<br>DetectionEventPublish | <b>Conditionally<br/>Required</b> | Finding confidence >=<br>theta_emit and<br>mapping resolved | Case-ready<br>detection<br>distribution       |
| OC-3 (reserved)                       | <b>Optional</b>                   | Deployment-specific<br>extensions                           | —                                             |

## Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
  - **Conditionally Required:** Must be implemented when trigger condition is met
  - **Optional:** May be implemented for enhanced functionality
- 

## Policies and HITL gates [Informative]

- `policy_refs`: SI-4 (Monitoring), AU-6 (Audit Review/Analysis), IR-4 (Incident Handling), **NIST 800-115** (testing/emulation).
- **HITL required:** any emulation (must be `sandbox_only`); any `DetectionEvent` affecting `CrownJewels`; `confidence < threshold`; `classification=C3`.
- **Automatic HITL escalation triggers:** `model_drift_detected=true`; `stakeholder_disagreement_score >= 0.5`; `FP_rate_7d > threshold`.
- **Manual outside agent:** purple-team design; post-hunt remediation ownership.

## SLOs and KPIs [Informative]

- `NotebookPublishAck_p95`  $\leq 60$  s
- `DetectionEmitLatency_p95`  $\leq 120$  s (from first qualifying `evidence_ts`)
- `HuntReproducibilityRate`  $\geq 99$  percent (digest match)
- `FalsePositiveRate_7d` (hunt-born)  $\leq 2$  percent

## Outputs index [Informative]

[OC-2 HuntNotebookPublish], [OC-1 Hunter-DetectionEventPublish]

---

## Technical Implementation Details (D4) [Informative]

### Model and training profile [Informative]

`model_id=hunter-text`; `temperature=0.0`; `max_tokens_out=700`

`prompt_pack_id=hunting-v1` (triage, pivot heuristics, ATT&CK mapping, notebook schema)

RAG: `sources={detections-kb, hunt-catalog, attack-encyclopedia, env-topology, fp-tp-history}`; `max_docs=12`; `min_similarity=0.78`; citations required

`fine_tuning/adapters`: none initially; eval on plan quality and mapping accuracy

guardrails: production data **read-only**; emulation calls blocked unless sandbox\_only present and attested

### **Memory and state [Informative]**

working\_memory.max\_tokens=4k; eviction=recency\_then\_importance  
episodic\_memory: per mission\_id journal (steps, queries, pivots, results digests); ttl=365d  
semantic\_memory: namespaces=["hunts","detections","attack","topology"]; embeddings=text-embedding-sec-v1; k=12  
durable\_state\_store: event-sourced hunt ledger; snapshot at notebook publish  
consistency: at-least-once (DetectionEvent); exactly-once (HuntNotebook per hunt\_id)  
idempotency: per Output Contracts

### **Decision and routing logic [Informative]**

#### **Triage score (0–100):**

$\text{triage} = 0.35 * \text{entity\_risk} + 0.25 * \text{intel\_weight} + 0.20 * \text{feature\_novelty} + 0.20 * \text{coverage\_gap}$

#### **Finding confidence (0–1):**

$\text{confidence} = 0.4 * \text{signal\_agreement} + 0.3 * \text{feature\_strength} + 0.2 * \text{rule\_support} + 0.1 * (1 - \text{fp\_history})$

#### **Emit rule:**

emit DetectionEvent if confidence  $\geq$  theta\_emit AND mapping\_refs resolved; else publish notebook with “no finding”.

Routing: detections→bus/REST; notebook→object/Git; backpressure when queue\_depth > threshold.

### **Model Risk Management [Informative]**

continuous\_validation: daily golden hunts + adversarial blends;  
thresholds: MappingAccuracy\_eval  $\geq$  99.0 percent; PlanQuality\_eval  $\geq$  target → else auto\_HITL;  
red\_team\_cycle: monthly ATT&CK emulations (in sandbox);  
rollback\_policy: revert model\_id on eval\_drop  $\geq$  1.5 pp over 48 h.

### **Transparency and Audit Trail (Approver/Auditor UX) [Informative]**

decision\_rationale\_template: hypothesis, scope, query plan, pivots, evidence\_refs, mapping\_refs, equations, hashes;  
UI/API: expose classification\_label, provenance.attestation, decision\_rationale\_url;  
audit\_log\_format: JSONL; retention by classification/legal\_hold.

### **Incident Response Integration [Informative]**

On finding, open/link case (CaseLink via IR platform) with notebook URIs and evidence digests; attach ATT&CK mapping and rationale.

### **Change Impact Assessment [Informative]**

Track hunt rule/threshold changes vs. findings & FP/TP; surface to governance dashboards.

### **Stakeholder Feedback Loop [Informative]**

Optionally capture HuntFeedback (labels={useful|no\_signal|noise}); feed governance-reviewed updates into hunt catalog.

### **Data Sovereignty and Legal Hold [Informative]**

Mark notebooks with classification; scrub sensitive samples or store as encrypted attachments; legal\_hold=true halts purge and extends TTL.

### **Interfaces (links only) [Informative]**

Consumes: SIEM/UEBA Feature Stream; Intel Hypotheses (REST/Git)  
Produces: OC-2 HuntNotebookPublish; OC-1 Hunter-DetectionEventPublish

### **Safety and abuse prevention [Informative]**

kill\_switch on provenance/constraint violation; sandbox guard for emulation; blast-radius caps on detection emissions; QPS/cost limits.

### **Testing and validation [Informative]**

Contract tests per Schema Capsules; offline replay of prior hunts; red-team ATT&CK runs (sandbox); drift checks + rollback.

### **Deployment and lifecycle [Informative]**

HPA on query/pivot queues; canary hunt plans; SBOM + attestations; sign artifacts and DetectionEvents.

---

### **References / Standards [Informative]**

NIST SP 800-160 Vol. 2; NIST SP 800-61 Rev. 2; NIST SP **800-115** (Technical Guide to Security Testing and Assessment); NIST SP 800-53 Rev. 5 (SI-4, AU-6, IR-4); MITRE ATT&CK/D3FEND; OpenTelemetry; CIS v8.

---

## MCP-Native Protocol Specification (D4) [Normative]

- **Native Protocol(s) Consumed:** SIEM/UEBA Feature Stream (REST/OTLP/Query API); Intel Hypotheses (REST/Git)
- **Native Protocol(s) Produced:** DetectionEvent (Kafka/AMQP/REST); HuntNotebook (object storage/Git)
- **MCP Context Fields:**
  - **Required:** mission\_id; role="AutonomousHunterAgent"; intent="hunt"; constraints includes sandbox\_only for emulations; policy\_refs; decision\_basis (evidence\_refs, confidence, explanation\_ref, mapping\_refs?); provenance (SPIFFE ID, signing KID, attestation)
  - **Optional:** classification (C1–C3); legal\_hold; case\_ref
- **Enforcement Note:** Consumers MUST validate signatures/provenance; **emulations** MUST prove sandbox\_only with attestation; HITL token is required for low-confidence or CrownJewels-related detections.
- **Versioning and compatibility; producers/consumers registry:** authoritative here; see Schema Capsules for accepted ranges/EOL.
- **Example payloads:** native and MCP-wrapped (authoritative, synchronized with Agent Blueprint).
- **Transparency hooks:** classification\_label, provenance.attestation, decision\_rationale\_url exposed to downstream UIs/APIs.

**Conformance:** This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

## D5. Exposure Mapping Agent (ASM)

### Agent Blueprint [Informative]

**Purpose:** Enumerate and track external and internal exposures across DNS, certificates, owned IP space, and cloud inventories. Emit **ASMExposure** and **RiskHotspot** with ownership and remediation hints.

### Operational Narrative [Informative]

#### Inputs used (authoritative sources):

- **DNS & Certificate Transparency (CT)** — domains/SANs, cert digests, validity windows, TXT/SPF/DMARC, A/AAAA/CNAME resolution.

- **IP Space Enumeration (IPAM/WHOIS/BGP)** — allocations, purpose/owner, contact rollups, route visibility, asset hints.
- **Cloud Inventory (AWS/Azure/GCP)** — public endpoints (ALB/ELB/AppGW/NEG), SG/NSG rules, tags/labels, exposure flags (internet-facing), service types.

### Model training / knowledge (what the LLM relies on):

- Prompt pack for **asset correlation & exposure scoring** (CT→DNS→IPAM→Cloud), ownership inference from tags/DNS patterns, and remediation playbooks.
- RAG sources: asset registry/CMDB, IPAM, cert archive, cloud inventories, historical takedowns, misconfig catalogs (e.g., open S3, weak TLS, missing WAF). Do **not** train on regulated evidence—use evidence\_refs.
- Guardrails: read-only credentials to inventories; **constraints must include** region:<code> and data\_residency:<jurisdiction>; deny any destructive actions (no live takedowns).

### Decisions it makes (deterministic + model-assisted):

- **Correlation:** unify CT/DNS, IPAM, and cloud objects into a single **asset\_ref**, infer **owner\_group** and **data\_class**.
- **Exposure scoring (0–100):** weigh internet-facing status, control gaps (WAF/TLS/HSTS/CSP), stale/unknown ownership, sensitive data tags, attack surface size.
- **Risk hotspotting:** aggregate exposures by **surface\_ref** (CIDR/domain/cloud resource) and flag **RiskHotspot** when score/velocity crosses thresholds.
- **Classification:** C1→C3 based on sensitivity (e.g., PCI tag or customer domains).

### Routing / where outputs go:

- **ASME Exposure** → secops.asm.exposure.v1 (Kafka/AMQP) or REST /asm/exposures.
- **RiskHotspot** → secops.asm.hotspot.v1 and case/ticket linkage when priority ≥ P2.
- **Time-series** → write exposure\_score trend to TSDB (Prometheus/Influx/OpenSearch metrics) for dashboards.

### Automation scope vs. manual/HITL:

- Fully automated: ingestion/correlation, scoring, owner inference, exposure emits, trend writes, ticket drafts with remediation hints.
- **HITL required:** takedown/enable-WAF/close-ports actions; any exposure touching **CrownJewels** or classification=C3; disputes on ownership.
- Manual outside agent: vendor coordination (DNS/CA), exception review boards, long-lived architecture changes.

---

**Security Domain:** Threat Intelligence, Situational Awareness, and Monitoring

**Inputs (native protocols consumed) [Informative]**

**1. DNS and Certificate Transparency (HTTPS/API)**

Native payload (normalized CT observation)

```
{
  "observed_at": "2025-08-15T13:10:00Z",
  "domain": "api.payments.example.com",
  "cert_sha256": "2a9f...bb71",
  "issuer_cn": "Example TLS CA R5",
  "not_before": "2025-08-14T12:00:00Z",
  "not_after": "2026-08-14T12:00:00Z",
  "sans": ["api.payments.example.com", "pay.example.com"],
  "ct_log": "argon2025",
  "first_seen": true,
  "dns_records": {
    "A": ["203.0.113.42"],
    "AAAA": [],
    "CNAME": [],
    "TXT": ["v=spf1 include:_spf.example.com -all"]
  }
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-d5-dnsct-1111-2222-3333-4444",
    "thread_id": "uuid-domain-api.payments.example.com",
    "task_id": "uuid-a1b2-c3d4-e5f6-7788",
    "role": "ExposureMappingAgent",
    "intent": "assess",
    "policy_refs": ["CM-8", "SI-4"],
    "constraints": ["region:us-east-1", "data_residency:US"],
    "decision_basis": {
      "evidence_refs": [
        "uri://ct/argon2025/2a9f...bb71",
        "uri://dns/api.payments.example.com/A"
      ],
      "confidence": 0.9,
      "explanation_ref": "uri://kb/asm/ct-to-asset-correlation"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/threat/exposure-mapping-agent",
      "signing_kid": "kid-dnsct-d5-01",
      "attestation_ref": "uri://slsa/attestations/asm@sha256:dnsct01"
    },
    "classification": "C2",
    "legal_hold": false
  },
}
```

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

```
"native_payload": { ... }  
}
```

## 2. IP Space Enumeration (IPAM/WHOIS/BGP)

Native payload (IPAM allocation snapshot)

```
{  
  "allocation_id": "ipam-alloc-007",  
  "cidr": "203.0.113.0/24",  
  "owner": "payments.edge",  
  "purpose": "public-edge",  
  "contacts": ["netops@example.com"],  
  "first_seen": "2023-02-01T00:00:00Z",  
  "last_verified": "2025-08-10T09:30:00Z",  
  "known_assets": [  
    {"ip": "203.0.113.42", "service": "https", "hostname": "api.payments.example.com"}  
  ]  
}
```

MCP-wrapped payload

```
{  
  "mcp_context": {  
    "mcp_version": "0.9",  
    "mission_id": "uuid-d5-ipspace-5555-6666-7777-8888",  
    "thread_id": "uuid-cidr-203.0.113.0-24",  
    "task_id": "uuid-9911-8822-7733-6644",  
    "role": "ExposureMappingAgent",  
    "intent": "assess",  
    "policy_refs": ["CM-8", "CA-7"],  
    "constraints": ["region:global", "data_residency:retain_origin"],  
  }  
}
```

```

"decision_basis": {
  "evidence_refs": ["uri://ipam/allocations/ipam-alloc-007"],
  "confidence": 0.95,
  "explanation_ref": "uri://kb/asm/ipam-bgp-whois-merging"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/threat/exposure-mapping-agent",
  "signing_kid": "kid-ipam-d5-02",
  "attestation_ref": "uri://slsa/attestations/asm@sha256:ipam02"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { ... }
}

```

### 3. Cloud Inventory (AWS/Azure/GCP APIs)

Native payload (public endpoint)

```

{
  "provider": "aws",
  "resource_type": "ALB",
  "resource_id": "arn:aws:elasticloadbalancing:us-east-1:123456789012:loadbalancer/app/payments-alb/50dc6c495c0c9188",
  "dns_name": "payments-alb-123456.us-east-1.elb.amazonaws.com",
  "scheme": "internet-facing",
  "listeners": [{"protocol": "HTTPS", "port": 443}],
  "security_groups": ["sg-0a1b2c3d4e5f6g7h"],
  "target_groups": ["arn:aws:elasticloadbalancing:us-east-1:....:targetgroup/payments-tg/73e2d6bc24d8a067"],
}

```

```

"tags": {"Owner": "payments.team", "DataClass": "PCI"}
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-d5-cloud-aaaa-bbbb-cccc-dddd",
    "thread_id": "uuid-aws-alb-payments",
    "task_id": "uuid-1122-3344-5566-7788",
    "role": "ExposureMappingAgent",
    "intent": "assess",
    "policy_refs": ["CM-8", "SC-7"],
    "constraints": ["region:us-east-1", "data_residency:US"],
    "decision_basis": {
      "evidence_refs": [
        "uri://aws/elbv2/loadbalancer/50dc6c495c0c9188",
        "uri://aws/ec2/security-groups/sg-0a1b2c3d4e5f6g7h"
      ],
      "confidence": 0.96,
      "explanation_ref": "uri://kb/asm/cloud-internet-facing-derivation"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/threat/exposure-mapping-agent",
      "signing_kid": "kid-cloud-d5-03",
      "attestation_ref": "uri://slsa/attestations/asm@sha256:cloud03"
    },
    "classification": "C2",

```

```
"legal_hold": false
},
"native_payload": { ... }
}
```

### Outputs (native) [Informative]

- **ASMEposure** (Kafka/AMQP/REST) — correlated exposure with owner and remediation hints.
- **RiskHotspot** (Kafka/AMQP/REST) — aggregated high-risk surface needing programmatic attention.
- **Time-series writes** (metrics/TSDB) — exposure\_score trend for dashboards/SLOs.

### MCP context (required) [Informative]

mission\_id; role="ExposureMappingAgent"; intent="assess"; policy\_refs (CM-8, CA-7, SI-4, SC-7 as applicable); **constraints includes** region:<code> and data\_residency:<jurisdiction>; provenance (SPIFFE ID, signing key, attestation)

### MCP context (optional) [Informative]

classification (C1–C3); decision\_basis (evidence\_refs, confidence, explanation\_ref); legal\_hold (true for takedown/investigation)

### Enforcement note [Informative]

PEPs MUST enforce **data\_residency** and **region** at ingress/egress; any downstream takedown/controls must require HITL and validated provenance; classification=C3 records require restricted routing and extended retention.

### NIST SP 800-160v2 linkage [Informative]

**Establish/Maintain Awareness** and **Anticipate** by continuously discovering and scoring exposures; enable Withstand/Recover via rapid owner attribution and remediation guidance.

### Automation feasibility [Informative]

High (enumeration, correlation, scoring, and publishing are automatable; takedown/control changes remain HITL).

---

### Output Contracts (merged) [Informative]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

## OC-1: ASME Exposure Publish [Informative]

- **Producer(s):** D5
- **Topic/Path:** Kafka secops.asm.exposure.v1, AMQP secops.asm.exposure.v1, REST POST /asm/exposures
- **Schema/Format:** ASME Exposure@1.1 (exposure\_id, asset\_ref, domain\_or\_ip, resource\_ref?, service, first\_seen, last\_seen, owner\_group, contacts[], data\_class, internet\_facing, controls\_present[], controls\_missing[], exposure\_score, rationale, remediation\_hints[], evidence\_refs[], created\_ts, classification)
- **Classification:** C1–C3
- **Delivery:** at-least-once (stream), idempotent REST
- **Ordering:** per asset\_ref
- **Idempotency-Key:** sha256(asset\_ref, service, domain\_or\_ip, controls\_hash)
- **Ack/Nack:** offset commit / HTTP 201; NACK on schema violation or missing owner inference
- **Timeouts/Retry:** emit ≤ 120s from observation; exp-backoff ≤ 5x
- **Side-Effects:** open/link ticket when exposure\_score ≥ threshold; notify owner\_group
- **HITL Token:** required for takedown/control-change recommendations
- **Observability:** trace\_id, mission\_id, decision\_basis.\*, classification\_label, provenance.attestation
- **Retention/TTL:** 1 year (extend if legal\_hold)

### Schema Capsule (OC-1) [Normative]

**Requirement Level:** Required

**Condition:** Always

schema\_id=ASME Exposure@1.1 | json\_schema\_uri=uri://schema/asm-exposure-1.1.json | sha256= | producers=D5 | consumers=ASM-UI-01, Ticket-01, SIEM-01 | accepts=1.0–1.1

**Conformance:** Normative.

---

## OC-2: Risk Hotspot Publish [Informative]

- **Producer(s):** D5

- **Topic/Path:** Kafka secops.asm.hotspot.v1, AMQP secops.asm.hotspot.v1, REST POST /asm/hotspots
- **Schema/Format:** RiskHotspot@1.0 (hotspot\_id, surface\_ref{cidr|domain|resource}, rationale, risk\_factors[], exposure\_count, exposure\_score\_agg, velocity\_7d, recommended\_actions[], priority{P1..P4}, ttl\_hours, evidence\_refs[], created\_ts)
- **Classification:** C1–C2
- **Delivery:** at-least-once; idempotent REST
- **Ordering:** per surface\_ref
- **Idempotency-Key:** sha256(surface\_ref, window\_floor\_24h, rationale\_hash)
- **Ack/Nack:** 201/offset commit; NACK on schema/priority mismatch
- **Timeouts/Retry:** emit<=120s from aggregation window close; exp-backoff<=5x
- **Side-Effects:** open program epic when priority ≤ P2; link constituent exposures
- **HITL Token:** required if recommended\_actions include takedown/control changes
- **Observability:** trace\_id, mission\_id, decision\_basis.\*, classification\_label, provenance.attestation
- **Retention/TTL:** ttl\_hours (default 168)

#### **Schema Capsule (OC-2) [Normative]**

**Requirement Level:** Conditionally Required

**Condition:** When exposure\_score\_agg >= threshold\_hotspot OR velocity\_7d >= velocity\_threshold

schema\_id=RiskHotspot@1.0 | json\_schema\_uri=uri://schema/asm-hotspot-1.0.json | sha256= | producers=D5 | consumers=ASM-UI-01, Governance-01, Ticket-01 | accepts=1.0

**Conformance:** Normative when condition is met.

#### **OC-3: ExposureScoreTimeseriesWrite [Informative, optional]**

- **Producer(s):** D5
- **Topic/Path:** TSDB metrics asm\_exposure\_score{asset\_ref=..., service=...}
- **Schema/Format:** ExposureScoreTS@1.0 (asset\_ref, service, exposure\_score, labels{owner, data\_class, region}, ts)

- **Classification:** C1
- **Delivery/Ordering:** best-effort; per asset\_ref
- **Idempotency-Key:** sha256(asset\_ref, service, ts\_floor\_5m)
- **Ack/Nack:** metrics backend write status
- **Side-Effects:** dashboard panels/SLOs
- **HITL Token:** none
- **Retention/TTL:** per metrics policy (90 days default)

### **Schema Capsule (OC-3) [Normative]**

**Requirement Level:** Optional

**Condition:** When dashboards/SLOs require trends

schema\_id=ExposureScoreTS@1.0 | json\_schema\_uri=uri://schema/asm-exposure-ts-1.0.json | producers=D5 | consumers=Dash-01 | accepts=1.0

**Conformance:** Normative if implemented or claimed.

### **State machine (concise) [Informative]**

states = { idle, ingesting, correlating, scoring, emitting\_exposure, aggregating\_hotspots, publishing\_hotspot, writing\_timeseries, contestation\_workflow, failed, closed }

transition(idle -> ingesting) when new observation arrives

transition(ingesting -> correlating) when schemas validate

transition(correlating -> scoring) when asset\_ref resolved

transition(scoring -> emitting\_exposure) when exposure\_score computed

transition(scoring -> aggregating\_hotspots) on window close or surge detected

transition(aggregating\_hotspots -> publishing\_hotspot) when thresholds met

transition(\* -> writing\_timeseries) whenever exposure\_score changes

transition(\* -> contestation\_workflow) on ownership dispute or stakeholder\_disagreement\_score >= 0.5

transition(\* -> failed) on schema/residency/region or timebox violation

timeout(emitting\_exposure, 120s) -> failed; retry<=5

idempotency\_key = sha256(asset\_ref, service, controls\_hash) for exposures;

sha256(surface\_ref, window\_floor\_24h, rationale\_hash) for hotspots

### **Output Contracts Summary [Normative]**

| Output Contract                      | Requirement Level             | Trigger Condition                                           | Business Impact                   |
|--------------------------------------|-------------------------------|-------------------------------------------------------------|-----------------------------------|
| OC-1 ASME Exposure Publish           | <b>Required</b>               | Always                                                      | Core exposure inventory & routing |
| OC-2 Risk Hotspot Publish            | <b>Conditionally Required</b> | exposure_score_agg >= threshold OR velocity_7d >= threshold | Program-level risk prioritization |
| OC-3 Exposure Score Timeseries Write | <b>Optional</b>               | Dashboards/SLOs need trends                                 | Visibility & trending             |

#### Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

---

#### Policies and HITL gates [Informative]

- policy\_refs: CM-8 (System Inventory), CA-7 (Continuous Monitoring), SI-4 (System Monitoring), SC-7 (Boundary Protection).
- **HITL required:** takedown/control-change recommendations; classification=C3; CrownJewels exposure; confidence<threshold.
- **Automatic HITL escalation:** model\_drift\_detected=true; stakeholder\_disagreement\_score>=0.5; unresolved owner mapping > N days.

#### SLOs and KPIs [Informative]

- ExposureEmitLatency\_p95 <= 120 s
- OwnerInferenceAccuracy >= 98 percent
- HotspotPublishLatency\_p95 <= 5 min window close
- UnknownOwner\_30d <= 2 percent of exposures
- RemediationHintCoverage >= 95 percent

## Outputs index [Informative]

[OC-1 ASMEExposurePublish], [OC-2 RiskHotspotPublish], [OC-3 ExposureScoreTimeseriesWrite]

---

## Technical Implementation Details (D5) [Informative]

### Model and training profile [Informative]

model\_id=asm-mapper-text; temperature=0.0; max\_tokens\_out=700  
prompt\_pack\_id=asm-v1 (correlation, scoring, remediation)  
RAG: sources={CMDB/asset-registry, IPAM, CT archive, cloud inventories, ticket history}; max\_docs=12; min\_similarity=0.78; citations required  
fine\_tuning/adapters: none initially; eval on correlation accuracy and remediation hint quality  
guardrails: enforce region and data\_residency constraints; block destructive APIs

### Memory and state [Informative]

working\_memory.max\_tokens=4k; eviction=recency\_then\_importance  
episodic\_memory: per mission\_id journal of observations→exposures/hotspots; ttl=365d  
semantic\_memory: namespaces=["assets","dns","ct","cloud","owners"];  
embeddings=text-embedding-sec-v1; k=12  
durable\_state\_store: event-sourced exposure ledger; snapshots daily  
consistency: at-least-once (ASMEExposure/RiskHotspot); best-effort (TSDB writes)  
idempotency: per Output Contracts

### Decision and routing logic [Informative]

#### Exposure score (0–100):

$$\text{exposure\_score} = 100 * (0.30 * \text{internet\_facing} + 0.20 * \text{controls\_gap} + 0.20 * \text{sensitivity} + 0.15 * \text{owner\_unknown} + 0.10 * \text{age\_norm} + 0.05 * \text{attack\_surface\_norm})$$
  
where

- internet\_facing in {0,1},
- controls\_gap = normalized count of missing controls (WAF,TLS>=1.2,HSTS,CSP,SG ingress),
- sensitivity in {0,1} from data\_class,
- owner\_unknown in {0,1},
- age\_norm =  $\min(1, \text{days\_exposed} / 90)$ ,
- attack\_surface\_norm =  $\min(1, \text{exposed\_listeners} / 6)$ .

**Hotspot priority:**

priority = P1 if exposure\_score\_agg >= 80 or velocity\_7d >= 3\*sigma else P2 if >= 65 else P3/P4.

Routing: exposures→bus/REST; hotspots→bus/REST + program epics; TS writes→metrics.

**Model Risk Management [Informative]**

continuous\_validation: daily correlation & scoring golden sets; adversarial cases (CT typosquats, stale IPAM);

thresholds: CorrelationAccuracy >= 99 percent; OwnerInferenceAccuracy >= 98 percent → else auto\_HITL;

red\_team\_cycle: monthly internet-facing misconfig drills;

rollback\_policy: revert model\_id on eval\_drop >= 1.5 pp for 48 h.

**Transparency and Audit Trail (Approver/Auditor UX) [Informative]**

decision\_rationale\_template: asset\_ref, inputs, score factors/weights, missing controls, owner inference path, evidence\_refs, hashes;

UI/API: expose classification\_label, provenance.attestation, decision\_rationale\_url;

audit\_log\_format: JSONL; retention bound to classification and legal\_hold.

**Incident Response Integration [Informative]**

Open/link tickets for priority ≤ P2; attach remediation playbook links; include owner\_group and contact list.

**Change Impact Assessment [Informative]**

Track effect of control enablement (e.g., WAF/TLS fix) on exposure\_score trends; surface deltas to governance dashboards.

**Stakeholder Feedback Loop [Informative]**

Accept owner/false-positive feedback; update mappings after governance review; never auto-train on regulated evidence.

**Data Sovereignty and Legal Hold [Informative]**

Honor data\_residency; mark C3 when sensitive tags present; legal\_hold=true freezes TTLs and suppresses external publication.

**Interfaces (links only) [Informative]**

Consumes: DNS/CT; IPAM/WHOIS/BGP; Cloud Inventory

Produces: OC-1 ASMEExposurePublish; OC-2 RiskHotspotPublish; OC-3

ExposureScoreTimeseriesWrite

## Safety and abuse prevention [Informative]

kill\_switch on residency/region violations; sandbox evaluation for takedown simulations; QPS/cost limits on cloud APIs.

## Testing and validation [Informative]

Contract tests per Schema Capsules; offline replay of CT/DNS/IPAM/cloud snapshots; red-team typosquat & stale IPAM scenarios; drift checks + rollback.

## Deployment and lifecycle [Informative]

HPA on ingest/correlation queues; canary scoring weights; SBOM + attestations; sign all outputs.

---

## References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (CM-8, CA-7, SI-4, SC-7); NIST SP 800-61 Rev. 2; CIS Controls v8; MITRE ATT&CK/D3FEND; CA/Browser Forum Baseline Requirements.

---

## MCP-Native Protocol Specification (D5) [Normative]

- **Native Protocol(s) Consumed:** DNS & CT (HTTPS/API); IPAM/WHOIS/BGP; Cloud Inventory (AWS/Azure/GCP APIs)
- **Native Protocol(s) Produced:** ASMEExposure (Kafka/AMQP/REST); RiskHotspot (Kafka/AMQP/REST); ExposureScoreTimeseriesWrite (metrics)
- **MCP Context Fields:**
  - **Required:** mission\_id; role="ExposureMappingAgent"; intent="assess"; policy\_refs; constraints includes region:<code> and data\_residency:<jurisdiction>; provenance (SPIFFE ID, signing key, attestation)
  - **Optional:** classification (C1–C3); decision\_basis (evidence\_refs, confidence, explanation\_ref); legal\_hold
- **Enforcement Note:** Consumers MUST validate signatures/provenance and enforce residency/region before storing/forwarding; HITL is mandatory for takedown/control-change actions.
- **Versioning and compatibility; producers/consumers registry:** authoritative here; see Schema Capsules for accepted ranges/EOL.

- **Example payloads:** native and MCP-wrapped (authoritative, synchronized with Agent Blueprint).
- **Transparency hooks:** `classification_label`, `provenance.attestation`, `decision_rationale_url` exposed to UIs/APIs.

**Conformance:** This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

## D6. Honeypot Controller Agent

### Agent Blueprint [Informative]

**Purpose:** Orchestrate deception networks and tokens. Place and rotate decoys and lures based on intel and segmentation posture. Emit **DeceptionEvent** on hits and **LureDeployPlan** for planned changes.

### Operational Narrative [Informative]

#### Inputs used (authoritative sources):

- **Intel Cues (IntelIOC / STIX / TAXII REST)** — IOCs, campaigns, TTPs, confidence, recommended lure types.
- **Segmentation Maps (SDN/NAC/Policy Controllers)** — segments, ACLs, tags, honeypot profiles, edge blocks, microseg posture.

#### Model training / knowledge (what the LLM relies on):

- Prompt pack for **deception strategy** (lure selection, placement safety checks, rotation cadence) and **engagement triage**.
- RAG sources: intel KB, historical deception hits and FP/TP labels, network topology and tags, asset sensitivity catalog, legal guardrails. Never train on regulated payloads; fetch via `evidence_refs`.
- Guardrails: constraints must include `decoy_label:<string>` and `strict_access:<policy>`; deny writes to production data stores; token material generation is sandboxed and signed.

#### Decisions it makes (deterministic + model-assisted):

- **Lure selection & placement** per segment risk, exposure, and allowed ingress/egress.
- **Rotation schedule** by TTL and campaign velocity; propose removals for stale lures.

- **Engagement triage** when a decoy is touched: classify severity, confidence, case linkage, and whether to escalate containment guidance.
- **Classification** elevation to C3 when payloads include high-value creds or malware samples.

#### Routing / where outputs go:

- **LureDeployPlan** → orchestration systems (deception fabric, SDN controller) or Git repo for infra-as-code PR.
- **DeceptionEvent** → detections bus and IR tooling; attach evidence\_refs and case\_ref when applicable.

#### Automation scope vs. manual/HITL:

- Fully automated: plan generation, safety checks, token synthesis, low-risk rotations, event emission.
- **HITL required:** placements in CrownJewels segments; any plan relaxing ACLs; engagement events with classification=C3 or malware sample exfil; takedown of legitimate assets accidentally targeted.
- Manual outside agent: red-team storyline design; legal review for adversary engagement beyond passive collection.

---

### Security Domain: Threat Intelligence, Situational Awareness, and Monitoring

#### Inputs (native protocols consumed) [Informative]

##### 1. Intel Cues (IntelIOC or STIX/TAXII)

Native payload

```
{
  "ioc_id": "IOC-2025-0815-009",
  "type": "domain",
  "value": "api-secure-login.com",
  "confidence": 0.88,
  "ttp": ["T1566.002", "T1105"],
  "campaign": "Campaign X",
  "sightings_24h": 3,
```

```

    "recommended_lures": ["credential-capture", "webshell-pseudo", "dns-beacon-sink"]
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-d6-intel-1111-2222-3333-4444",
    "thread_id": "uuid-ioc-IOC-2025-0815-009",
    "task_id": "uuid-a1b2-c3d4-e5f6-7788",
    "role": "HoneypotControllerAgent",
    "intent": "deploy",
    "policy_refs": ["SI-4", "SC-7", "IR-4"],
    "constraints": ["decoy_label:DECOY-DO-NOT-TOUCH",
"strict_access:allow(secops,hunters)"],
    "decision_basis": {
      "evidence_refs": ["uri://intel/ioc/IOC-2025-0815-009"],
      "confidence": 0.9,
      "explanation_ref": "uri://kb/deception/lure-selection-from-ttp"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/threat/honeypot-controller-agent",
      "signing_kid": "kid-intel-d6-01",
      "attestation_ref": "uri://slsa/attestations/deception@sha256:intel01"
    },
    "classification": "C2",
    "legal_hold": false
  },
}

```

```
"native_payload": { ... }  
}
```

## 2. Segmentation Maps (SDN/NAC/Policy Controller)

Native payload

```
{  
  "controller": "nsx-t",  
  "version": "2025-08-10",  
  "segments": [  
    {  
      "name": "prod-web",  
      "cidrs": ["10.10.10.0/24"],  
      "acl_in": ["internet", "dmz"],  
      "acl_out": ["prod-app"],  
      "microseg": true,  
      "tags": ["internet_facing", "pci_scope"]  
    },  
    {  
      "name": "deception-net",  
      "cidrs": ["10.250.0.0/24"],  
      "acl_in": ["prod-web", "prod-app", "internet"],  
      "acl_out": [],  
      "microseg": true,  
      "honeypot_profiles": ["webapp-l7", "ssh-medium", "smb-high-interact"]  
    }  
  ],  
  "edge_blocks": [  
    {"from": "deception-net", "to": "pci-db", "action": "deny"}  
  ]  
}
```

```

]
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-d6-seg-5555-6666-7777-8888",
    "thread_id": "uuid-segmap-2025-08-10",
    "task_id": "uuid-9911-8822-7733-6644",
    "role": "HoneypotControllerAgent",
    "intent": "deploy",
    "policy_refs": ["SC-7", "SI-4"],
    "constraints": ["decoy_label:DECOY-DO-NOT-TOUCH",
"strict_access:allow(secops,hunters)", "no_prod_data:true"],
    "decision_basis": {
      "evidence_refs": ["uri://sdn/nsx-t/segmaps/2025-08-10"],
      "confidence": 0.96,
      "explanation_ref": "uri://kb/deception/placement-strategy#microseg"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/threat/honeypot-controller-agent",
      "signing_kid": "kid-seg-d6-02",
      "attestation_ref": "uri://slsa/attestations/deception@sha256:seg02"
    },
    "classification": "C2",
    "legal_hold": false
  },

```

```
"native_payload": { ... }  
}
```

### **Outputs (native) [Informative]**

- **LureDeployPlan** to orchestration systems or Git (infra-as-code).
- **DeceptionEvent** to detections bus (Kafka/AMQP/REST) for SOC triage and IR linkage.

### **MCP context (required) [Informative]**

mission\_id; role="HoneypotControllerAgent"; intent="deploy"; policy\_refs (SI-4, SC-7, IR-4); constraints includes decoy\_label:<string> and strict\_access:<policy>; provenance (SPIFFE ID, signing key, attestation)

### **MCP context (optional) [Informative]**

classification (C1–C3); decision\_basis (evidence\_refs, confidence, explanation\_ref); legal\_hold (true when deception hit escalates)

### **Enforcement note [Informative]**

PEPs MUST verify strict\_access before accepting any placement; decoys MUST be isolated from production data flows; tokens must be uniquely labeled with decoy\_label and signed provenance; engagement events with classification=C3 require legal\_hold=true and restricted routing.

### **NIST SP 800-160v2 linkage [Informative]**

Anticipate and Withstand through deception and adversary engagement; Recover via early high-signal detection and containment triggers.

### **Automation feasibility [Informative]**

High with guardrails for access, placement, and rotation.

---

## **Output Contracts (merged) [Informative]**

### **OC-1: LureDeployPlanPublish [Informative]**

- **Producer(s):** D6
- **Topic/Path:** REST POST /deception/plans, Git sec/deception/plans/<plan\_id>.yaml, or bus secops.deception.plan.v1

- **Schema/Format:** LureDeployPlan@1.0 (plan\_id, targets[], access\_policy, rollback\_ttl\_minutes, evidence\_refs[], provenance.attestation, created\_ts)
  - targets[]: segment, cidr, profile, service\_decoy, token\_types[], ttl\_hours
  - access\_policy: allowed\_groups[], deny\_all\_else=true
- **Classification:** C1–C2
- **Delivery:** exactly-once per plan\_id (Git commit or idempotent REST)
- **Ordering:** per segment or plan\_id
- **Idempotency-Key:** sha256(plan\_id, targets\_digest, access\_policy\_digest)
- **Ack/Nack:** 201 Created / merge commit hash; NACK on policy or safety violation
- **Timeouts/Retry:** ack<=60s; exp-backoff<=5x; dead-letter to deception.plan.dlq
- **Side-Effects:** create PR or change ticket; post preview diff; preflight safety checks recorded
- **HITL Token:** required for CrownJewels segments or ACL relaxations
- **Observability:** trace\_id, mission\_id, decision\_basis.\*, classification\_label, provenance.attestation
- **Retention/TTL:** 1 year (extend on legal\_hold)

### Schema Capsule (OC-1) [Normative]

**Requirement Level:** Required

**Condition:** Always

schema\_id=LureDeployPlan@1.0 | json\_schema\_uri=uri://schema/lure-deploy-plan-1.0.json | sha256= | producers=D6 | consumers=Deception-Orch-01, SDN-01, GitOps-01 | accepts=1.0

**Conformance:** Normative.

### OC-2: DeceptionEventPublish [Informative]

- **Producer(s):** D6
- **Topic/Path:** Kafka secops.deception.events.v1, AMQP secops.deception.events.v1, REST POST /deception/events
- **Schema/Format:** DeceptionEvent@1.1 (event\_id, decoy\_ref, src\_ip, src\_asn?, dst\_service, lure\_type, payload\_sample\_ref?, first\_seen, last\_seen, severity, confidence, case\_ref?, evidence\_refs[], classification, legal\_hold, created\_ts)

- **Classification:** C2 by default; set C3 when high-value creds or malware samples are present
- **Delivery:** at-least-once (stream); idempotent REST
- **Ordering:** per decoy\_ref
- **Idempotency-Key:** sha256(decoy\_ref, src\_ip, first\_seen\_floor\_60s)
- **Ack/Nack:** offset commit / HTTP 201; NACK on schema or provenance failure
- **Timeouts/Retry:** emit<=30s from hit detection; exp-backoff<=5x
- **Side-Effects:** auto-open IR case for severity>=high; attach payload\_sample\_ref to restricted store; apply legal\_hold=true for C3
- **HITL Token:** required before containment recommendations involving production networks
- **Observability:** trace\_id, mission\_id, decision\_basis.\*, classification\_label, provenance.attestation
- **Retention/TTL:** 7 years (or per legal policy)

### Schema Capsule (OC-2) [Normative]

**Requirement Level:** Conditionally Required

**Condition:** When a decoy or lure is touched and engagement is detected  
 schema\_id=DeceptionEvent@1.1 | json\_schema\_uri=uri://schema/deception-event-1.1.json | sha256= | producers=D6 | consumers=SIEM-01, SOAR-01, IR-Case-01 | accepts=1.0–1.1

**Conformance:** Normative when condition is met.

### State machine (concise) [Informative]

states = { idle, analyzing\_intel, evaluating\_segments, planning\_deploy, publishing\_plan, monitoring, triaging\_hit, emitting\_event, contestation\_workflow, failed, closed }  
 transition(idle -> analyzing\_intel) when new intel cue arrives  
 transition(analyzing\_intel -> evaluating\_segments) when lure types selected  
 transition(evaluating\_segments -> planning\_deploy) when safe placements identified  
 transition(planning\_deploy -> publishing\_plan) when safety checks pass and HITL not required  
 transition(publishing\_plan -> monitoring) on ACK  
 transition(monitored -> triaging\_hit) when decoy triggered  
 transition(triaging\_hit -> emitting\_event) when severity/confidence computed  
 transition(\* -> contestation\_workflow) on stakeholder\_disagreement\_score >= 0.5 or

legal query  
 transition(\* -> failed) on policy/residency/segmentation violation  
 timeout(publishing\_plan, 60s) -> failed; retry<=5  
 idempotency\_key = sha256(plan\_id, targets\_digest, access\_policy\_digest) for plans;  
 sha256(decoy\_ref, src\_ip, first\_seen\_floor\_60s) for events

---

## Output Contracts Summary [Normative]

| Output Contract               | Requirement Level             | Trigger Condition                                  | Business Impact                     |
|-------------------------------|-------------------------------|----------------------------------------------------|-------------------------------------|
| OC-1<br>LureDeployPlanPublish | <b>Required</b>               | Always                                             | Safe, auditable deception placement |
| OC-2<br>DeceptionEventPublish | <b>Conditionally Required</b> | When a decoy/lure is touched and engagement occurs | High-signal alerts for SOC and IR   |

### Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

---

## Policies and HITL gates [Informative]

- policy\_refs: SI-4 (Monitoring), SC-7 (Boundary Protection), IR-4 (Incident Handling).
- **HITL required:** CrownJewels segments, ACL relaxations, classification=C3 engagements, or confidence<threshold for containment.
- **Automatic HITL escalation triggers:** model\_confidence < theta\_low; model\_drift\_detected=true; stakeholder\_disagreement\_score >= 0.5; decoy placement overlaps production data paths.

## SLOs and KPIs [Informative]

- PlanPublishAck\_p95 <= 60 s
- HitToEventLatency\_p95 <= 30 s

- FalseEngagementRate\_7d <= 1 percent
- UnsafePlacementAbortRate >= 99.9 percent (preflight catches)
- RotationFreshness\_p95 <= target TTL

## Outputs index [Informative]

[OC-1 LureDeployPlanPublish], [OC-2 DeceptionEventPublish]

---

## Technical Implementation Details (D6) [Informative]

### Model and training profile [Informative]

model\_id=deception-controller-text; temperature=0.0; max\_tokens\_out=700  
 prompt\_pack\_id=deception-v1 (lure selection, placement safety, engagement triage)  
 RAG: sources={intel-kb, segmentation-maps, deception-hit-ledger, asset-sensitivity, legal-guardrails}; max\_docs=12; min\_similarity=0.78; citations required  
 fine\_tuning/adapters: none initially; eval on placement safety and hit triage accuracy  
 guardrails: enforce strict\_access and decoy\_label presence; deny prod data writes;  
 token material signed and scoped

### Memory and state [Informative]

working\_memory.max\_tokens=4k; eviction=recency\_then\_importance  
 episodic\_memory: per mission\_id journal of plans and hits; ttl=365d  
 semantic\_memory: namespaces=["segmaps","intel","decoys","owners"];  
 embeddings=text-embedding-sec-v1; k=12  
 durable\_state\_store: event-sourced deception ledger; snapshots at each plan publish  
 consistency: exactly-once per plan\_id (plans); at-least-once (events)  
 idempotency: per Output Contracts

### Decision and routing logic [Informative]

#### Placement score (0–100):

placement = 0.35\*threat\_relevance + 0.25\*ingress\_exposure +  
 0.20\*segmentation\_safety + 0.10\*owner\_clarity + 0.10\*novelty

- threat\_relevance from TTP overlap and sightings\_24h
- ingress\_exposure from acl\_in and tags (internet\_facing)
- segmentation\_safety penalizes egress to prod or pci-db
- owner\_clarity favors segments with clear operational ownership
- novelty encourages varied lure coverage across surfaces

**Engagement severity (low/medium/high):**

severity = high if (payload\_high\_value or cred\_use\_attempt or crownjewel\_proximity)  
else medium if toolmarks\_present else low

**Hit confidence (0–1):**

confidence =  $0.5 * \text{sensor\_signal} + 0.3 * \text{token\_uniqueness} + 0.2 * \text{repeatability}$

Routing: plans→Git/Orchestrator/bus; events→detections bus and IR; backpressure  
when queue\_depth > threshold.

**Model Risk Management [Informative]**

continuous\_validation: daily simulated placements and replay hits;

thresholds: SafetyEval\_pass >= 99.9 percent; TriageAccuracy >= 99.0 percent → else  
auto\_HITL;

red\_team\_cycle: monthly deception bypass drills;

rollback\_policy: revert model\_id on eval\_drop >= 1.5 pp for 48 h.

**Transparency and Audit Trail (Approver/Auditor UX) [Informative]**

decision\_rationale\_template: lure choice, placement score, safety checks, ACL diffs,  
evidence\_refs, hashes;

UI/API: expose classification\_label, provenance.attestation, decision\_rationale\_url;

audit\_log\_format: JSONL; retention aligns with classification and legal\_hold.

**Incident Response Integration [Informative]**

Emit DeceptionEvent with case\_ref for sev>=high; attach payload\_sample\_ref to  
restricted malware store; auto-notify on-call.

**Change Impact Assessment [Informative]**

Track rotation impact on engagement rate and FP; surface to governance dashboards.

**Stakeholder Feedback Loop [Informative]**

Accept operator feedback on plan safety and hit usefulness; integrate after governance  
review; never auto-train on regulated payloads.

**Data Sovereignty and Legal Hold [Informative]**

Honor residency constraints for payload samples; legal\_hold=true freezes TTL and  
restricts routing.

**Interfaces (links only) [Informative]**

Consumes: Intel Cues; Segmentation Maps

Produces: OC-1 LureDeployPlanPublish; OC-2 DeceptionEventPublish

## Safety and abuse prevention [Informative]

kill\_switch on provenance or access-policy violations; sandbox token generation; blast-radius caps on placements per window; QPS/cost limits.

## Testing and validation [Informative]

Contract tests per Schema Capsules; offline replay of hit streams; segmentation safety unit tests; drift checks + rollback.

## Deployment and lifecycle [Informative]

HPA on planning and monitoring queues; canary plans; SBOM + attestations; sign all outputs.

---

## References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (SI-4, SC-7, IR-4); NIST SP 800-61 Rev. 2; MITRE ATT&CK/D3FEND; deception best practices; GitOps for network policy.

---

## MCP-Native Protocol Specification (D6) [Normative]

- **Native Protocol(s) Consumed:** Intel Cues (IntelIOC/STIX/TAXII); Segmentation Maps (SDN/NAC/Policy Controller)
- **Native Protocol(s) Produced:** LureDeployPlan (Git/REST/bus); DeceptionEvent (Kafka/AMQP/REST)
- **MCP Context Fields:**
  - **Required:** mission\_id; role="HoneypotControllerAgent"; intent="deploy"; policy\_refs; constraints includes decoy\_label:<string> and strict\_access:<policy>; provenance (SPIFFE ID, signing KID, attestation)
  - **Optional:** classification (C1–C3); decision\_basis (evidence\_refs, confidence, explanation\_ref); legal\_hold
- **Enforcement Note:** Consumers MUST validate signatures/provenance, enforce strict\_access, and prevent any decoy from accessing or receiving production data unintentionally; legal\_hold is mandatory for C3 payload events.
- **Versioning and compatibility; producers/consumers registry:** authoritative here; see Schema Capsules for accepted ranges/EOL.

- **Example payloads:** native and MCP-wrapped (authoritative, synchronized with Agent Blueprint).
- **Transparency hooks:** `classification_label`, `provenance.attestation`, `decision_rationale_url` exposed to downstream UIs/APIs.

**Conformance:** This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.